YK7

ملفات الرصد المؤسسي

الأمن السيبراني في
بيئة المقاولات والهندسة

من حماية المعلومات إلى مرونة المشروع والأنظمة التشغيلية

IT/OT • BIM/CDE • Supply Chain • Cyber Resilience

مرجع تطبيقي في الأمن السيبراني للبيئة الهندسية الرقمية



إعداد وتحليل: منصة الرصد الاستراتيجي | YK7

فريق إعداد الكتاب: المهندس سهيل ياسر قطب

الإشراف العلمي والتحريري: د. ياسر قطب

September 2026

dryasserkotb.com

بيانات الكتاب

موضوع الكتاب ومنهجه

يعرض هذا الكتاب إطارًا علميًا وتطبيقيًا لفهم الأمن السيبراني لقطاع المقاولات والهندسة والبيئة المبنية، مع توظيف الحالة التطبيقية فقط لتوضيح السياق.

ضبط منهجي

المصطلحات المستقرة مثل NIST CSF وISO/IEC 27001 وIEC 62443 وBIM وOT وIAM تُعرض بوصفها مصطلحات وأطرًا مستقرة بحسب مصادرها. أما «السطح السيبراني للمشروع» و«نموذج YK7 السباعي للقراءة المؤسسية السيبرانية» و«Cyber Closeout» بصيغته المستخدمة هنا فهي **مصطلحات/أدوات إجرائية ضمن YK7** مستفيدة من الأدبيات، وليست معايير دولية باسمها.

حقوق النص والتحرير والتصميم محفوظة لمنصة الرصد الاستراتيجي | YK7. يسمح بالاقتباس العلمي مع النسبة والمصدر. لا تمثل المادة تدقيقًا أو اختبار اختراق أو رأيًا قانونيًا، ولا تغني عن تقييم ميداني مصرح به.

كلمة الإصدار

الأمن لا يبدأ من الأداة

مراجع الموضوع: [R01] [R02] [R22]

يبدأ الأمن السيبراني من فهم المؤسسة: ما الذي تحاول إنجازه؟ ما الأصول التي تعتمد عليها؟ من يثق في من؟ ما مسارات الوصول؟ وما الذي يحدث إذا تعطلت وظيفة حرجة؟

في قطاع المقاولات والهندسة، يزداد هذا السؤال أهمية لأن المشروع يربط التصميم والتوريد والتنفيذ والموردين والمواقع المتغيرة والمنصات الرقمية والأنظمة التشغيلية. وهنا تتقاطع السرية مع سلامة النسخة، والتوافر مع الجدول الزمني، والأمن مع السلامة، والهوية مع العلاقة التعاقدية.

> **«الأمن السيبراني لا يبدأ من الأداة... بل من فهم المؤسسة.»**

لهذا لا يقدم هذا المرجع قائمة منتجات، بل لغة لفهم الخطر، ثم أدوات وأطرًا تساعد على تحويله إلى قرار قابل للتنفيذ.

طريقة الاستخدام

كيف تقرأ هذا المرجع؟

لمهندس IT/Cyber

الأبواب 3-7 و11 تقدم المفاهيم والضوابط وعلاقات IT/OT.

لصاحب القرار

ابدأ بالأبواب 1، 2، 10، 12 لفهم الحوكمة والمخاطر وخارطة الطريق.

للباحث والمتدرب

استخدم قاموس المصطلحات والاختصارات والمراجع للرجوع المنهجي.

لمهندس المشروع/BIM

اقرأ البابين 2 و8، ثم الطرف الثالث والتسليم السيبراني.

قاعدة القراءة

عند كل موضوع نفرق بين: **المفهوم المستقر**، **والتطبيق في قطاع المقاولات**، وأداة **YK7 الإجرائية** إن وجدت، ثم نربط الصفحة بمراجع مختارة المرتبطة بها.

المنهج العلمي

من المصادر إلى المادة القابلة للاستخدام

مراجع الموضوع: [R01] [R02] [R06] [R07] [R09] [R10] [R17] [R18] [R19]

تم بناء المادة على أربعة مستويات: المعايير والأطر الرسمية، الإرشادات الحكومية/التقنية، الدراسات العلمية المحكمة في الأمن السيبراني والبيئة المبنية، ثم التحليل الإجرائي الذي يربط تلك المعرفة بسياق المقاولات والهندسة.

Operational Guidance

CISA CPGs، Remote Access، StopRansomware، KEV، NIST IR 8374r1.

Standards & Frameworks

NIST CSF 2.0، NIST SP 800-82، ISO/IEC 27001/27002، ISO 19650-5، IEC 62443.

YK7 Analysis

تنظيم الرصد، ضبط المصطلحات، وربط التقنية بالسياق وجودة القرار.

Peer-Reviewed Research

دراسات التوأم الرقمي، OT في مواقع البناء، وتقييم المخاطر السيبرانية في المشاريع.

خريطة المحتوى

الأبواب العلمية
من الأساس إلى التطبيق

01 الأساس قبل الأداة
من أمن المعلومات إلى المرونة السيبرانية

02 المقاولات والهندسة كمنظومة رقمية
لماذا أصبحت بيئة المشروع سطحًا سيبرانيًا؟

03 الأصول والبيانات
لا حماية بلا معرفة ما نملك

04 الهوية والوصول
الثقة تُدار قبل أن تُراقب

05 الشبكات والسحابة والمواقع
الاتصال هو بنية عمل وبنية مخاطرة

06 الطرف الثالث وسلسلة الإمداد
حدود المؤسسة تمتد مع المورد

07 OT وICS وIACS
حين يصبح الأمن مسألة تشغيل وسلامة

08 BIM وCDE والتوأم الرقمي
المعلومة الهندسية أصبحت أصلًا متصلًا

09 مشهد التهديدات
من التصيد إلى الابتزاز وتعطيل المشروع

10 الحوكمة والأطر والمعايير
كيف نستخدم المرجع دون تحويله إلى قائمة جامدة؟

11 الكشف والاستجابة والتعافي
الحادث لا يبدأ عند اكتشافه ولا ينتهي بإغلاق التذكرة

12 النضج والقياس وخارطة الطريق
من معرفة الخطر إلى تحسين قابل للقياس

الملاحق

القاموس والأدوات للاستخدام العملي

دليل الاختصارات

أكثر من 60 اختصارًا: IT/ OT/BIM/CDE/IAM/ SIEM وغيرها.

قاموس المصطلحات

أكثر من 60 مصطلحًا مع التمييز بين المستقر والمعياري والإجرائي في YK7.

قوائم فحص

خط أساس، المورد، OT، BIM/CDE، Ransomware، وإغلاق المشروع.

مقارنة الأطر

NIST CSF، ISO/IEC 27001، ISO 19650-5، CISA CPGs، IEC 62443.

القاموس لا يحل محل السياق؛ لكنه يمنع أن يتحول المصطلح إلى شعار بلا معنى.

مشهد 2026

لماذا لا تكفي المعرفة القديمة؟

مراجع الموضوع: [R20] [R21]

المشهد يتغير بسرعة، لكن ذلك لا يلغي الأساسيات؛ بل يزيد قيمة الحوكمة والجرد والهوية والتحديث والمراقبة والاستجابة.

$4.99M	48%	31%
متوسط عالمي لتكلفة خرق البيانات وفق IBM 2026.	ارتباط الطرف الثالث ضمن نتائج DBIR 2026 العالمية.	استغلال الثغرات كنقطة دخول ضمن نتائج DBIR 2026 العالمية.

تحذير منهجي

هذه مؤشرات عالمية من تقارير تجارية واسعة، وليست نسب احتمال خاصة بشركات المقاولات أو دولة محددة. تُستخدم لقراءة الاتجاه، لا لتقدير خطر مؤسسة بعينها.

ضبط المصطلح

ثلاث طبقات لا ينبغي خلطها

مصطلح معياري

مرتبط بسياق معيار محدد: Zone/Conduit وSL-T في IEC 62443، Current Target Profile في NIST CSF.

مصطلح مستقر

له استخدام معروف في الأدبيات والمعايير: IAM، OT، Zero Trust، Risk، BIM.

مصطلح تسويقي

قد تُستخدمه الشركات بمرونة، لا يُعامل كقدرة مثبتة دون تعريف أو دليل.

مصطلح YK7 إجرائي

صياغة لتنظيم التحليل مثل «السطح السيبراني للمشروع» و«القراءة المؤسسية السيبرانية».

الدقة في الأمن تبدأ أحيانًا من اللغة: إذا لم نحدد ما نعنيه بالمصطلح فلن نعرف ما الذي نقيسه.

الباب 01

الأساس قبل الأداة

من أمن المعلومات إلى المرونة السيبرانية

01 الأمن السيبراني وأمن المعلومات: أين يلتقيان؟
02 ثالوث CIA: السرية والسلامة والتوافر
03 الأصل والتهديد والثغرة والمخاطر والضابط
04 سطح الهجوم ومسارات الثقة
05 المخاطر القائمة على السياق
06 المرونة السيبرانية لا تساوي المنع
07 من التقنية إلى القرار

الباب 01 | 01

الأمن السيبراني وأمن المعلومات: أين يلتقيان؟

مراجع الموضوع: [R01] [R07] [R08]

أمن المعلومات يهتم بحماية المعلومات بصرف النظر عن وسيطها، بينما يركز الأمن السيبراني على المخاطر الناشئة في الفضاء الرقمي والأنظمة المتصلة. في المشاريع الهندسية لا يكفي الفصل بين المفهومين؛ فالرسومات والعقود والبيانات الهندسية تنتقل بين منصات وأجهزة وشبكات وموردين، فتلتقي حماية المعلومة مع حماية البيئة الرقمية التي تحملها.

في بيئة المقاولات والهندسة

التمييز مهم عند توزيع المسؤوليات: قد يكون تصنيف الوثائق والسياسات ضمن حوكمة أمن المعلومات، بينما تتولى فرق الأمن السيبراني إدارة الهوية، الحماية التقنية، الرصد والاستجابة. النضج الحقيقي يربط الاثنين تحت إدارة مخاطر واحدة.

سؤال تحقق

هل تتوزع المسؤوليات بوضوح بين حوكمة المعلومات وفرق الحماية السيبرانية؟

ما الذي يتغير في القرار؟

حدّد مسؤولية حماية المعلومات ومسؤولية حماية الأنظمة المتصلة ضمن سجل مخاطر واحد.

الباب 01 | 02

ثالوث CIA: السرية والسلامة والتوافر

مراجع الموضوع: [R07] [R08] [R09]

السرية Confidentiality تمنع الإفصاح غير المصرح، والسلامة Integrity تحافظ على صحة المعلومات وعدم تغييرها دون تصريح، والتوافر Availability يضمن الوصول في الوقت المطلوب. في بيئة المقاولات قد تكون سلامة النسخة الهندسية وتوافرها مساويين أو أعلى من السرية في بعض اللحظات التشغيلية.

في بيئة المقاولات والهندسة

نسخة رسم خاطئة أو غير معتمدة قد تقود إلى تنفيذ مادي خاطئ؛ وانقطاع منصة المشروع قد يوقف فريقًا؛ وتسريب التسعير قد يضر بالمنافسة. لذلك لا يجوز اختزال الأمن في منع التسريب.

سؤال تحقق

هل يحدد تصنيف البيانات أثر فقد السرية أو التغيير أو تعطل الوصول؟

ما الذي يتغير في القرار؟

وازن بين سرية الوثيقة وسلامة نسختها وتوافرها وفق وظيفة المشروع.

الباب 01 | 03

الأصل والتهديد والثغرة والمخاطر والضابط

مراجع الموضوع: [R01] [R07]

الأصل Asset هو ما له قيمة ويحتاج حماية؛ التهديد Threat سبب محتمل للضرر؛ الثغرة Vulnerability ضعف يمكن استغلاله؛ الخطر Risk يجمع احتمال الحدث وأثره في سياق المؤسسة؛ والضابط Control إجراء إداري أو تقني أو مادي لتغيير مستوى الخطر.

في بيئة المقاولات والهندسة

التفريق يمنع اللغة المضخمة: وجود ثغرة لا يعني وقوع حادث، ووجود تهديد لا يحدد وحده أولوية المعالجة. الأولوية تنشأ عندما نربط الأصل الحرج بالتهديد والثغرة والأثر وسياق العمل.

سؤال تحقق

هل يوثق سجل المخاطر علاقة الأصل بالتهديد والثغرة والضابط المختار؟

ما الذي يتغير في القرار؟

لا تُعالج ثغرة بمعزل عن الأصل والتهديد المحتمل والأثر التشغيلي.

الباب 01 | 04

سطح الهجوم ومسارات الثقة

مراجع الموضوع: [R05] [R15] [R22]

سطح الهجوم Attack Surface هو مجموع النقاط التي يمكن أن يتفاعل عبرها مهاجم مع النظام. أما مسار الثقة فهو العلاقات التي تسمح بالوصول بين أشخاص وأجهزة وخدمات وموردين. في المشروع قد يكون الحساب المؤقت أو الوصول البعيد أو جهاز الموقع جزءًا من السطح حتى إن لم يظهر على مخطط الشبكة المركزي.

في بيئة المقاولات والهندسة

المنظور المؤسسي الأوسع يبدأ بالسؤال: من يثق في من؟ من يملك حسابًا؟ ما مدة الصلاحية؟ وما الذي يحدث عند انتقال الموظف أو انتهاء عقد المورد؟ هذا التفكير يسبق شراء أدوات إضافية.

سؤال تحقق

هل تتوافر خريطة حديثة للاتصالات والحسابات ونقاط الدخول الحرجة؟

ما الذي يتغير في القرار؟

رتّب حماية مسارات الوصول الخارجية والداخلية بحسب إمكان الاستغلال.

الباب 01 | 05

المخاطر القائمة على السياق

مراجع الموضوع: [R01] [R02] [R10]

Risk-based Approach يعني ترتيب القرارات الأمنية وفق احتمال الضرر وأثره وأهمية الأصل وسياق التشغيل، بدل تطبيق قائمة واحدة على جميع الأنظمة. فالضابط المقبول في بيئة مكتبية قد يكون غير مناسب لنظام OT لا يحتمل إعادة التشغيل المفاجئ.

في بيئة المقاولات والهندسة

في المقاولات يجب أن تدخل عوامل الجدول الزمني، السلامة، الالتزامات التعاقدية، متطلبات العميل، الموردين، والموقع المؤقت في تقدير الخطر.

سؤال تحقق

هل تُفسَّر أولوية المعالجة باحتمال الضرر وأثره على المشروع؟

ما الذي يتغير في القرار؟

امنح الأولوية لما يهدد سير الأعمال وسلامة الأشخاص لا لمجرد عدد التنبيهات.

الباب 01 | 06

المرونة السيبرانية لا تساوي المنع

مراجع الموضوع: [R01] [R03] [R06]

Cyber Resilience هي قدرة المؤسسة على الاستمرار في تقديم الوظائف المهمة والاستجابة والتعافي حتى عند وقوع اضطراب سيبراني. لا توجد مؤسسة تضمن منع كل حادث؛ لذلك تصبح النسخ القابلة للاستعادة، بدائل الاتصال، العزل، إجراءات الطوارئ، والقرار الإداري جزءًا من الأمن.

في بيئة المقاولات والهندسة

الانتقال من عقلية "منع الاختراق" إلى "إدارة الخطر واستمرار الوظيفة" مهم في المشروعات التي يرتبط فيها التوقف بتكلفة وتأخير ومطالبات تعاقدية.

سؤال تحقق

هل يمكن استمرار الوظائف الحرجة أو استعادتها ضمن زمن مقبول؟

ما الذي يتغير في القرار؟

اعتمد بدائل تشغيل وخطط استعادة للوظائف المهمة إلى جانب إجراءات المنع.

الباب 01 | 07

من التقنية إلى القرار

مراجع الموضوع: [R01] [R07]

الأمن السيبراني ليس ملكًا لقسم IT وحده. فهو يمس الإدارة العليا، المشروع، المشتريات، الموارد البشرية، الشؤون القانونية، الجودة، السلامة، الموردين، والتشغيل. وظيفة الحوكمة هي تحديد من يملك القرار ومن يقبل الخطر ومن يتحمل تنفيذ الضوابط.

في بيئة المقاولات والهندسة

هذه النظرة هي نقطة انطلاق هذا المرجع: التقنية تضيف قدرة، لكن المؤسسة تحدد القيمة والأولوية وحدود المخاطر المقبولة.

سؤال تحقق

من يقبل الخطر المتبقي ومن يملك قرار التصعيد عند تأثر المشروع؟

ما الذي يتغير في القرار؟

وزّع قرارات المخاطر والتمويل والمتابعة على الجهات المالكة للعمليات.

الباب 02

المقاولات والهندسة كمنظومة رقمية

لماذا أصبحت بيئة المشروع سطحًا سيبرانيًا؟

02 دورة حياة المشروع كدورة حياة للبيانات

01 AEC وEPC وTurnkey: المصطلح قبل التحليل

04 تعدد الأطراف واتساع حدود المؤسسة

03 المواقع المؤقتة ليست بيئات مؤقتة أمنيًا

06 من BIM إلى الأنظمة السيبرانية الفيزيائية

05 البيانات التجارية والهندسية والتشغيلية

07 تعريف إجرائي: السطح السيبراني للمشروع

الباب 02 | 01

AEC وEPC وTurnkey: المصطلح قبل التحليل

مراجع الموضوع: [R17] [R22]

اختصار AEC Architecture, Engineering and Construction؛ وEPC يشير عادة إلى Engineering, Procurement and Construction؛ وTurnkey إلى نموذج تسليم يتولى فيه المقاول نطاقًا متكاملًا يصل إلى جاهزية التسليم وفق العقد. هذه ليست نماذج أمنية، لكنها تحدد تدفقات المعلومات وعدد الأطراف ومسؤوليات التكامل.

في بيئة المقاولات والهندسة

كلما اتسع نطاق التكامل زادت علاقات الثقة والحسابات والأنظمة والوثائق التي ينبغي إدارتها، ولذلك يرتبط نموذج العمل مباشرة بسطح المخاطر.

سؤال تحقق

هل تعكس حدود المسؤولية السيبرانية أدوار المقاول والمورد والمالك؟

ما الذي يتغير في القرار؟

اربط نطاق الأمن بنموذج التعاقد والتوريد والمسؤوليات في EPC وTurnkey .

الباب 02 | 02

دورة حياة المشروع كدورة حياة للبيانات

مراجع الموضوع: [R09] [R22]

تمر المعلومات من العطاء والتصميم إلى التوريد والتنفيذ والاختبار والتشغيل والتسليم. ومع كل مرحلة تتغير الحساسية والملاك والصلاحيات والنسخ المعتمدة.

في بيئة المقاولات والهندسة

التحكم الأمني الجيد يتبع دورة الحياة: إنشاء، مشاركة، اعتماد، تعديل، أرشفة، تسليم، ثم حذف أو احتفاظ وفق الالتزامات.

سؤال تحقق

هل تُراجع الصلاحيات والنسخ وقرارات الاحتفاظ عند كل مرحلة؟

ما الذي يتغير في القرار؟

عامل معلومات المشروع كأصول تتغير ملكيتها وحساسيتها عبر المراحل.

الباب 02 | 03

المواقع المؤقتة ليست بيئات مؤقتة أمنيًا

مراجع الموضوع: [R04] [R15]

الموقع قد يبدأ بسرعة باستخدام شبكات لاسلكية، أجهزة محمولة، أجهزة مقاولين، كاميرات، طابعات، وحدات تخزين، وخدمات سحابية. المؤقت تشغيليًا قد يترك أثرًا دائمًا إذا بقي حساب أو VPN أو جهاز بعد انتهاء المشروع.

في بيئة المقاولات والهندسة

إغلاق المشروع Cyber Closeout يجب أن يشمل إلغاء الحسابات، سحب الأجهزة، إغلاق قنوات الوصول، أرشفة السجلات والملفات، والتحقق من التسليم الآمن.

سؤال تحقق

هل تُعرف أجهزة الموقع ومستخدموه وتواريخ إغلاق حساباتهم؟

ما الذي يتغير في القرار؟

أخضع شبكة الموقع المؤقت للجرد والضبط قبل تشغيل الخدمات المتصلة.

الباب 02 | 04

تعدد الأطراف واتساع حدود المؤسسة

مراجع الموضوع: [R04] [R17]

المشروع الحديث شبكة من مالك واستشاري ومقاول رئيسي ومقاولين فرعيين وموردين ومصنعي معدات ومتكاملي نظم. لذلك لا تتطابق حدود الأمن مع حدود الهيكل التنظيمي.

في بيئة المقاولات والهندسة

العقود، إدارة الطرف الثالث، واجراءات الدخول والخروج يجب أن تنظر إلى المورد كشريك في سطح المخاطر لا كجهة خارجية بعيدة.

سؤال تحقق

هل توجد موافقات وحدود واضحة للمشاركة والوصول لدى المقاولين الفرعيين؟

ما الذي يتغير في القرار؟

حدّد مالك المخاطر عند انتقال البيانات بين أطراف المشروع المتعددة.

الباب 02 | 05

البيانات التجارية والهندسية والتشغيلية

مراجع الموضوع: [R08] [R09]

Commercial Data تشمل التسعير والعطاءات والمطالبات والتفاوض؛ Engineering Data تشمل النماذج والرسومات والمواصفات؛ Operational Data قد تشمل حالة المعدات والأنظمة والتحكم. تختلف آثار التسريب أو التعديل أو الفقد بين كل فئة.

في بيئة المقاولات والهندسة

التصنيف يساعد على تطبيق حماية متناسبة بدل معاملة كل الملفات بالمستوى نفسه.

سؤال تحقق

هل تعرف الجهة ماذا يجب حمايته من تسريب أو تغيير أو تعطيل؟

ما الذي يتغير في القرار؟

افصل ضوابط الوثائق التجارية والتصميمية والبيانات التشغيلية بحسب أثرها.

الباب 02 | 06

من BIM إلى الأنظمة السيبرانية الفيزيائية

مراجع الموضوع: [R17] [R18]

التحول الرقمي يتجاوز ملفات BIM إلى أجهزة استشعار وإنترنت الأشياء والطائرات المسيّرة والمعدات المتصلة والتوأم الرقمي. حين يؤثر القرار الرقمي في العالم المادي نقترب من مفهوم Cyber-Physical Systems.

في بيئة المقاولات والهندسة

هذا التحول يضيف فرصًا إنتاجية، لكنه يوسع العواقب الممكنة من فقد بيانات إلى تعطيل أو خطر سلامة.

سؤال تحقق

هل حُدد أثر تعطل الاتصال أو العبث بالبيانات على الوظيفة المادية؟

ما قيمة سلامة المعلومة؟

أدخل آثار السلامة والتشغيل عند تقييم الأجهزة المستشعرة والأنظمة المتصلة.

الباب 02 | 07

تعريف إجرائي: السطح السيبراني للمشروع

مراجع الموضوع: [R01] [R22]

نستخدم داخل YK7 مصطلح "السطح السيبراني للمشروع" بوصفه تعريفًا إجرائيًا: مجموع الأصول الرقمية والهويات والحسابات والأجهزة والاتصالات والأطراف الخارجية والأنظمة التشغيلية التي يعتمد عليها المشروع أو تؤثر في قراره وتنفيذه.

في بيئة المقاولات والهندسة

هذا المصطلح مستوحى من مفهوم Attack Surface وإدارة المخاطر، لكنه ليس معياراً مستقراً في الأدبيات بهذا الاسم؛ والغرض منه تنظيم القراءة المؤسسية.

سؤال تحقق

هل تشمل خريطة المشروع الموردين والهويات والتطبيقات والأجهزة والاتصالات؟

ما الذي يتغير في القرار؟

استخدم السطح السيبراني للمشروع كأداة حصر تحليلية لا كمقياس دولي.

الباب 03

الأصول والبيانات

لا حماية بلا معرفة ما نملك

01 Asset Inventory: الجرد أصل الرؤية
02 تصنيف المعلومات
03 سلامة النسخة والتحكم في الإصدار
04 Mobile وEndpoint وRemovable Media
05 Cloud وSaaS وShared Responsibility
06 Backup ليس نسخة إضافية
07 الاحتفاظ والإتلاف الآمن

الباب 03 | 01

Asset Inventory: الجرد أصل الرؤية

مراجع الموضوع: [R01] [R02]

جرد الأصول ليس قائمة أجهزة فقط؛ يشمل الأجهزة، الخوادم، التطبيقات، الخدمات السحابية، الحسابات الخدمية، الأصول OT، ومعلومات المالك والحالة والأهمية.

في بيئة المقاولات والهندسة

الهدف أن تستطيع المؤسسة الإجابة: ماذا لدينا؟ أين؟ من يملكه؟ ما وظيفته؟ وما علاقته بعمليات حرجة؟

سؤال تحقق

هل لكل أصل رقمي أو تشغيلي مالك معلوم وحالة دعم وتصنيف مخاطر؟

ما الذي يتغير في القرار؟

ابدأ بملكية الأصول وحالتها وأهميتها قبل توزيع أدوات الحماية.

الباب 03 | 02

تصنيف المعلومات

مراجع الموضوع: [R07] [R08] [R09]

التصنيف Data Classification يربط حساسية المعلومات بضوابط مناسبة مثل المشاركة والتخزين والطباعة والاحتفاظ. يمكن تصميم مستويات بسيطة: عام، داخلي، سري، وحساس/مقيد وفق سياق المؤسسة.

في بيئة المقاولات والهندسة

المهم ألا تتحول التسميات إلى زخرفة؛ يجب أن تغير سلوك المستخدم والمنصة والصلاحيات.

سؤال تحقق

هل تتغير صلاحيات مشاركة المخططات والعطاءات بحسب تصنيفها؟

ما الذي يتغير في القرار؟

اربط ضوابط المشاركة والتخزين والاحتفاظ بحساسية كل نوع من البيانات.

الباب 03 | 03

سلامة النسخة والتحكم في الإصدار

مراجع الموضوع: [R09] [R22]

Version Control وApproval Workflow جوهريان في الملفات الهندسية. الأمن هنا يلتقي بالجودة: من عدل الملف؟ متى؟ هل النسخة معتمدة؟ وهل القرار الميداني بُني على النسخة الصحيحة؟

في بيئة المقاولات والهندسة

Integrity في قطاع البناء ليست مفهومًا تقنيًا مجردًا؛ قد تصبح شرطًا لسلامة التنفيذ.

سؤال تحقق

هل يمكن إثبات من عدّل الملف ومتى ومن اعتمد آخر نسخة؟

ما قيمة سلامة المعلومة؟

اجعل النسخة المعتمدة ومسار اعتمادها أساسًا لحماية القرار الهندسي.

الباب 03 | 04

Endpoint وMobile وRemovable Media

مراجع الموضوع: [R08] [R13]

أجهزة المهندسين والمواقع تتنقل بين الشبكات وتتعامل مع ملفات وموردين ووسائط USB. إدارة الأجهزة تشمل التحديث، EDR/AV، تشفير القرص، قفل الشاشة، إدارة الامتيازات، وسياسة الوسائط القابلة للإزالة.

في بيئة المقاولات والهندسة

المخاطر لا تعالج بالحظر المطلق دائمًا؛ بعض المعدات تحتاج وسائط مادية، وهنا تصبح العملية المصرح بها والفحص والتسجيل بدائل أكثر واقعية.

سؤال تحقق

هل تُشفَّر الأجهزة المحمولة وتخضع وسائط USB لفحص وسياسة معلومة؟

ما الذي يتغير في القرار؟

اضبط أجهزة الموقع ووسائط النقل ضمن سياسة واحدة تشمل الفقد والبرمجيات.

الباب 03 | 05

Cloud وSaaS وShared Responsibility

مراجع الموضوع: [R01] [R08]

الخدمة السحابية لا تنقل كل المسؤولية إلى المزود. Shared Responsibility تعني أن توزيع المسؤوليات يختلف حسب نموذج الخدمة، لكن المؤسسة تبقى مسؤولة عن الهوية، البيانات، الإعدادات والصلاحيات في جوانب جوهرية.

في بيئة المقاولات والهندسة

أكثر الأخطاء شيوعًا ليست كسر تشفير المزود بل إعداد خاطئ أو حساب مخترق أو مشاركة أوسع من الحاجة.

سؤال تحقق

هل يبيّن عقد الخدمة السحابية ما يحميه المزود وما تحميه المؤسسة؟

ما الذي يتغير في القرار؟

وثّق حدود مسؤولية المؤسسة والمزوّد عن الحسابات والنسخ والبيانات.

الباب 03 | 06

Backup ليس نسخة إضافية

مراجع الموضوع: [R06] [R14]

النسخ الاحتياطي Backup هو قدرة مصممة للتعافي؛ قيمته تُثبت بالاستعادة Restore. يجب التفكير في النسخ غير المتصلة أو المحمية، فصل صلاحيات الإدارة، تواتر النسخ، وتحديد RPO/RTO.

في بيئة المقاولات والهندسة

في ransomware قد تكون النسخ نفسها هدفًا للمهاجم، لذلك فصلها وحمايتها واختبارها جزء من المرونة.

سؤال تحقق

متى اختُبرت استعادة ملفات المشروع وما الزمن الفعلي للوصول إليها؟

ما قيمة سلامة المعلومة؟

قيّم النسخ الاحتياطي بنتائج اختبارات الاستعادة لا بعدد النسخ المخزنة.

الباب 03 | 07

الاحتفاظ والإتلاف الآمن

مراجع الموضوع: [R07] [R08]

Retention يحدد مدة الاحتفاظ بناء على الحاجة القانونية والتعاقدية والتشغيلية؛ Secure Disposal يقلل المخاطر عند انتهاء الحاجة.

في بيئة المقاولات والهندسة

التكديس غير المحدود يزيد البيانات المعرضة ويصعب الاكتشاف والاستجابة. دورة حياة المعلومات يجب أن تنتهي بقرار واضح لا بنسيان الملف.

سؤال تحقق

هل توجد مدد احتفاظ معتمدة وطريقة موثقة لإتلاف بيانات المشروع؟

ما الذي يتغير في القرار؟

اجمع بين التزامات الاحتفاظ ومتطلبات الإتلاف وإثبات التنفيذ.

الباب 04

الهوية والوصول

الثقة تُدار قبل أن تُراقب

01 IAM: إدارة الهوية والوصول
02 MFA والمصادقة المقاومة للتصيد
03 Least Privilege وNeed-to-Know
04 RBAC وABAC
05 Joiner-Mover-Leaver
06 PAM والحسابات ذات الامتياز
07 الوصول البعيد والموردون

الباب 04 | 01

IAM: إدارة الهوية والوصول

مراجع الموضوع: [R05] [R08]

Identity and Access Management يجمع إنشاء الهوية، المصادقة، التفويض، المراجعة والإلغاء. الهدف ليس فقط تسجيل الدخول بل ربط الوصول بشخص أو خدمة ودور ومدة وحاجة.

في بيئة المقاولات والهندسة

في المشروعات المتغيرة، دقة IAM تصبح مهمة بسبب انتقال الأشخاص وتبدل الفرق والموردين.

سؤال تحقق

هل تُراجع الحسابات والصلاحيات وتُلغى فور انتهاء الحاجة إليها؟

ما الذي يتغير في القرار؟

اجعل دورة حياة الهوية مرتبطة بصاحب الحساب والمهمة وتاريخ الانتهاء.

الباب 04 | 02

MFA والمصادقة المقاومة للتصيد

مراجع الموضوع: [R05] [R13]

Multi-Factor Authentication تطلب أكثر من عامل مستقل. ليست كل MFA متساوية؛ بعض الأساليب أكثر مقاومة للتصيد من رموز يمكن خداع المستخدم لإدخالها.

في بيئة المقاولات والهندسة

الأولوية للحسابات الإدارية، البريد، VPN، الخدمات السحابية، والوصول البعيد.

سؤال تحقق

هل تستخدم الحسابات الحساسة والموردون مصادقة مقاومة للتصيد حيث يلزم؟

ما الذي يتغير في القرار؟

اختر وسائل مصادقة ملائمة لمستوى التعرض ولا تفترض تماثل كل MFA .

الباب 04 | 03

Least Privilege وNeed-to-Know

مراجع الموضوع: [R05] [R08]

أقل امتياز يعني منح الحد الأدنى من الصلاحيات اللازمة للمهمة، بينما Need-to-Know يربط الاطلاع بالحاجة العملية.

في بيئة المقاولات والهندسة

المشكلة ليست فقط في من يملك صلاحية الآن، بل في الصلاحيات المتراكمة التي لم تعد لازمة.

سؤال تحقق

هل يقتصر الوصول الفعلي لكل مستخدم على ملفات ومهام عمله الحالية؟

ما الذي يتغير في القرار؟

امنع التوسع التلقائي للصلاحيات عند انتقال الأشخاص بين المشاريع.

الباب 04 | 04

RBAC وABAC

مراجع الموضوع: [R05] [R08]

Role-Based Access Control يربط الصلاحيات بالأدوار، بينما Attribute-Based Access Control يمكن أن يأخذ صفات المستخدم والجهاز والموقع والسياق.

في بيئة المقاولات والهندسة

RBAC غالبًا أسهل كبداية، لكن البيئات المعقدة قد تحتاج سياقًا إضافيًا للوصول الحساس.

سؤال تحقق

هل يمكن تقييد الوصول بحسب الدور والمشروع والجهاز ومدة التكليف؟

ما الذي يتغير في القرار؟

اختبر ملاءمة الأدوار والصفات السياقية لقرارات مشاركة النماذج.

الباب 04 | 05

Joiner-Mover-Leaver

مراجع الموضوع: [R04] [R08]

JML هو ضبط دورة حياة المستخدم: عند الانضمام تُنشأ الصلاحيات، وعند تغيير الدور تُراجع، وعند المغادرة تُلغى.

في بيئة المقاولات والهندسة

أخطر نقطة في المشاريع المؤقتة هي بقاء صلاحية بعد انتهاء الحاجة، خصوصًا للموردين والمقاولين.

سؤال تحقق

هل يُغلق حساب المغادر أو يُحدَّث عند تغيير المشروع دون تأخير؟

ما الذي يتغير في القرار؟

اربط ضوابط الانضمام والنقل والمغادرة بالتغيير الفعلي في فرق العمل.

الباب 04 | 06

PAM والحسابات ذات الامتياز

مراجع الموضوع: [R05] [R08]

Privileged Access Management يركز على الحسابات القادرة على تغيير الأنظمة أو الإعدادات الحساسة. يشمل تقليل الحسابات، فصل الهوية الإدارية، التسجيل، وإدارة الأسرار والجلسات عند الحاجة.

في بيئة المقاولات والهندسة

اختراق حساب إداري يغير حجم الأثر؛ لذلك لا يعامل كحساب مستخدم عادي.

سؤال تحقق

هل تُسجل الجلسات الحساسة ويفصل الحساب الإداري عن الحساب اليومي؟

ما الذي يتغير في القرار؟

احصر الحسابات عالية الامتياز وحدّد الاعتماد والمراجعة لكل استخدام.

الباب 04 | 07

الوصول البعيد والموردون

مراجع الموضوع: [R04] [R15]

Remote Access ضرورة تشغيلية في كثير من المشاريع، لكنه ينبغي أن يكون مسارًا معروفًا، مملوكًا، محدود الزمن، محميًا بـMFA، ومراقبًا، مع تجنب الأدوات غير المعتمدة أو الوصول الدائم بلا حاجة.

في بيئة المقاولات والهندسة

Jump Server أو بوابة وصول يمكن أن تقلل الاتصال المباشر وتوفر نقطة تحكم وتسجيل.

سؤال تحقق

هل يمكن إثبات وقت تفعيل وصول المورد وتعطيله ومن أجازه؟

أين تمتد الثقة؟

اجعل دعم المورد البعيد مؤقتًا ومصرحًا ومحصورًا في النظام المطلوب.

الباب 05

الشبكات والسحابة والمواقع

الاتصال هو بنية عمل وبنية مخاطرة

01 Network Segmentation

02 Firewall وACL وDMZ

03 VPN وZTNA

04 Wi-Fi وGuest وSite Networks

05 Logging وSIEM

06 Vulnerability Management

07 Patch Management في IT وOT

الباب 05 | 01

Network Segmentation

مراجع الموضوع: [R02] [R11]

التقسيم الشبكي يفصل الأصول والمستخدمين إلى مناطق وفق الوظيفة والمخاطر، ويحد من الحركة الجانبية. لا يكفي وجود VLAN إذا كانت قواعد الوصول تسمح بكل شيء.

في بيئة المقاولات والهندسة

في المشاريع يمكن الفصل بين شبكات المستخدمين، الضيوف، الكاميرات/IoT، الخدمات الإدارية، وOT بحسب الحاجة.

سؤال تحقق

هل تمنع قواعد المرور غير الضروري بين شبكة المكتب والتشغيل والضيوف؟

ما الذي يتغير في القرار؟

قسّم الشبكات وفق وظيفة الأنظمة وحدود الثقة لا بمجرد الاسم التقني.

الباب 05 | 02

Firewall وACL وDMZ

مراجع الموضوع: [R08] [R11]

الجدار الناري يطبق قواعد مرور؛ ACL قائمة تحكم وصول؛ DMZ منطقة وسيطة للخدمات التي تحتاج اتصالًا بين شبكات مختلفة. هذه أدوات، وليست استراتيجية بحد ذاتها.

في بيئة المقاولات والهندسة

التصميم الجيد يبدأ بتدفق الأعمال المطلوب ثم يفتح الحد الأدنى اللازم، لا العكس.

سؤال تحقق

هل توجد قواعد وصول واسعة بلا مالك أو حاجة تشغيلية معروفة؟

ما الذي يتغير في القرار؟

راجع الغرض من كل قاعدة جدار ناري واحتفظ بتبرير استثنائها.

الباب 05 | 03

VPN وZTNA

مراجع الموضوع: [R05] [R15]

VPN ينشئ قناة مشفرة للوصول إلى شبكة أو موارد، بينما Zero Trust Network Access يميل إلى الوصول المقيّد للموارد بناء على الهوية والسياق بدل منح حضور واسع على الشبكة.

في بيئة المقاولات والهندسة

الاختيار يعتمد على البيئة؛ المصطلحات لا تعني أن منتجًا واحدًا يحل مشكلة الثقة.

سؤال تحقق

هل نطاق وصول المقاول أو المورد أوسع من النظام الذي يحتاجه؟

ما الذي يتغير في القرار؟

امنح المستخدم وصولاً محددًا للموارد بدل فتح الشبكة كاملة متى أمكن.

الباب 05 | 04

Wi-Fi وGuest وSite Networks

مراجع الموضوع: [R08] [R13]

الشبكات اللاسلكية في المواقع مرنة لكن تحتاج ضبطًا: تشفير مناسب، فصل الضيوف، تغيير الإعدادات الافتراضية، إدارة نقاط الوصول، وتعقب الأجهزة المتصلة.

في بيئة المقاولات والهندسة

المرونة التشغيلية لا تبرر شبكة مسطحة تجمع معدات الموقع ومستخدمي المكتب وضيوفا.

سؤال تحقق

هل تُغيَّر إعدادات نقاط الوصول الافتراضية ويُراجع مستخدموها؟

ما الذي يتغير في القرار؟

افصل ضيوف الموقع والمعدات المتصلة عن الشبكات التي تحمل بيانات حساسة.

الباب 05 | 05

Logging وSIEM

مراجع الموضوع: [R03] [R08]

Logging هو تسجيل الأحداث؛ SIEM يجمع ويربط السجلات لدعم الكشف والتحقيق. لا قيمة لكمية السجلات إذا لم توجد أسئلة كشف وحالات استخدام ومدة احتفاظ مناسبة.

في بيئة المقاولات والهندسة

ينبغي البدء بالأحداث المهمة: تسجيل الدخول، تغييرات الامتيازات، الوصول البعيد، تغييرات الأنظمة الحساسة، والتنبيهات الأمنية.

سؤال تحقق

هل يمكن تتبّع دخول الحسابات الحساسة وتعديل الصلاحيات والوصول البعيد؟

ما الذي يتغير في القرار؟

ابدأ بحالات الكشف المطلوبة ثم حدّد السجلات اللازمة للاحتفاظ والتحليل.

الباب 05 | 06

Vulnerability Management

مراجع الموضوع: [R01] [R16]

إدارة الثغرات هي دورة: اكتشاف، تقييم، ترتيب أولوية، معالجة، تحقق، وتوثيق الاستثناء. لا تُعالج كل CVE بالسرعة نفسها؛ الأولوية ترتفع عند وجود استغلال فعلي وأصل مكشوف وأثر عال.

في بيئة المقاولات والهندسة

يمكن استخدام CISA KEV كمدخل لتحديد الثغرات المعروفة بالاستغلال الفعلي، دون أن يحل ذلك محل تحليل السياق.

سؤال تحقق

هل يربط ترتيب الثغرات بين الاستغلال المكشوف وأهمية الأصل وتأثير العطل؟

ما الذي يتغير في القرار؟

قدّم الثغرات المستغلة فعليًا على المعالجات الأقل أثرًا بعد تقييم السياق.

الباب 05 | 07

Patch Management في IT وOT

مراجع الموضوع: [R02] [R12]

التحديث في IT قد يكون روتينيًا نسبيًا، أما OT فقد يحتاج نافذة توقف واختبار توافق وموافقة المورد. لهذا لا يعني تأخر الترقيع إهمالًا دائمًا؛ قد يلزم ضابط تعويضي مثل العزل والمراقبة وتقليل الوصول.

في بيئة المقاولات والهندسة

القرار الأمني الناضج يوازن المخاطر مع السلامة والتوافر والدعم الفني.

سؤال تحقق

هل تُوثَّق نافذة الصيانة ومخاطر التأجيل وضوابطه التعويضية؟

ما الذي يختلف عن IT؟

نسّق ترقيع أنظمة التشغيل الصناعي مع مالك العملية واختبار التوافق.

الباب 06

الطرف الثالث وسلسلة الإمداد

حدود المؤسسة تمتد مع المورد

01 C-SCRM: إدارة مخاطر سلسلة الإمداد
02 التأهيل الأمني للمورد
03 المتطلبات التعاقدية
04 Remote Support
05 Firmware Supply وSoftware Chain
06 Offboarding للمورد
07 مؤشرات مخاطر الموردين

الباب 06 | 01

C-SCRM: إدارة مخاطر سلسلة الإمداد

مراجع الموضوع: [R04]

Cybersecurity Supply Chain Risk Management تنظم مخاطر المنتجات والخدمات والموردين عبر دورة الشراء والتكامل والتشغيل.

في بيئة المقاولات والهندسة

في المقاولات لا يقتصر المورد على البرمجيات؛ قد يكون مصنّع معدات أو متكامل أنظمة أو مقاولًا يحتفظ بوصول عن بعد.

سؤال تحقق

هل يشمل تقييم التوريد أثر الاختراق أو التوقف على سلسلة المشروع؟

ما الذي يتغير في القرار؟

أدخل مخاطر البرمجيات والمكونات وخدمات المورد ضمن قرار الشراء.

الباب 06 | 02

التأهيل الأمني للمورد

مراجع الموضوع: [R04] [R13]

Vendor Due Diligence يجب أن يكون متناسبًا مع الخطر: ما البيانات التي يراها؟ ما الوصول الذي يملكه؟ هل يدخل OT؟ ما أثر توقف خدمته؟

في بيئة المقاولات والهندسة

لا تحتاج كل جهة استبيانًا ضخمًا؛ يكفي أحيانًا عدد قليل من أسئلة عالية القيمة إذا كان النطاق محدودًا.

سؤال تحقق

هل صُنّف المورد حسب بياناته وصلاحياته واعتماد المشروع عليه؟

ما الذي يتغير في القرار؟

اربط عمق فحص المورد بما يمكنه الوصول إليه وبالأثر المحتمل لتعطله.

الباب 06 | 03

المتطلبات التعاقدية

مراجع الموضوع: [R04] [R09]

العقد يمكن أن يحدد الإخطار بالحوادث، ضوابط الوصول، حماية المعلومات، حق المراجعة، إدارة المقاولين الفرعيين، إعادة البيانات، الإتلاف، والالتزام بمتطلبات محددة.

في بيئة المقاولات والهندسة

صياغة الأمن في العقد تحول التوقع إلى التزام قابل للإدارة.

سؤال تحقق

هل يتناول العقد الإخطار بالحوادث وإنهاء الوصول وإعادة البيانات؟

ما الذي يتغير في القرار؟

حوّل اشتراطات الأمن في العقد إلى التزامات قابلة للإثبات والمراجعة.

الباب 06 | 04

Remote Support

مراجع الموضوع: [R02] [R15]

دعم المورد عن بعد مفيد لكنه يرفع المخاطر إذا كان دائمًا أو مشتركًا أو بلا سجل. الأفضل هو وصول معرف، محدود الوقت، عبر قناة معتمدة، بمصادقة قوية، وتسجيل مناسب.

في بيئة المقاولات والهندسة

في OT قد يلزم أيضًا تنسيق تشغيلي قبل فتح الجلسة ومراقبتها.

سؤال تحقق

هل يُمنح المورد حسابًا معرفًا وصلاحية محدودة الوقت مع تسجيل الجلسة؟

ما الذي يتغير في القرار؟

لا تجعل استعجال الدعم سببًا لمنح المورد قناة دخول دائمة.

الباب 06 | 05

Firmware Supply Chain وSoftware

مراجع الموضوع: [R04]

المعدات الحديثة تحتوي برمجيات ثابتة Firmware ومكونات برمجية وتحديثات. سؤال "من هو المورد؟" يمتد إلى من يطور ويوقع ويحدث المكونات.

في بيئة المقاولات والهندسة

إدارة سلسلة الإمداد تنظر إلى الأصالة والدعم والتحديثات والضعف المعروف وأصل البرمجيات حيث يكون ذلك متاحاً.

سؤال تحقق

هل يمكن تتبّع الجهة التي وقّعت تحديث الجهاز وآلية التحقق منه؟

أين تمتد الثقة؟

افحص مصادر التحديثات وسلسلة البرمجيات المضمنة في المعدات قبل الاعتماد.

الباب 06 | 06

Offboarding للمورد

مراجع الموضوع: [R04] [R15]

إغلاق العلاقة يجب أن يسحب الحسابات والشهادات والمفاتيح والأجهزة، ويؤكد إعادة/حذف البيانات، ويغلق قنوات الوصول.

في بيئة المقاولات والهندسة

خطر "الحساب المنسي" شائع لأن إنهاء العقد الإداري لا يغلق آليًا كل أثر تقني.

سؤال تحقق

هل توجد أدلة على إلغاء كل منافذ الوصول بعد انتهاء العقد؟

ما الذي يتغير في القرار؟

اجعل إغلاق علاقة المورد عملية أمنية تشمل الحسابات والبيانات والمفاتيح.

الباب 06 | 07

مؤشرات مخاطر الموردين

مراجع الموضوع: [R01] [R04]

يمكن قياس عدد الحسابات الخارجية، نسبة MFA، الوصول غير المستخدم، الموردين ذوي الوصول الحرج، زمن إلغاء الوصول، ونسبة العقود التي تشمل متطلبات أمنية.

في بيئة المقاولات والهندسة

المؤشر ليس غاية؛ قيمته في إظهار اتجاه الخطر وفتح قرار واضح.

سؤال تحقق

هل تُقاس الحسابات الخارجية الحرجة وزمن إلغائها والاستثناءات المفتوحة؟

أين تمتد الثقة؟

اختر مؤشرات تعكس التعرض الفعلي للموردين لا عدد النماذج المكتملة.

الباب 07

OT وICS وIACS

حين يصبح الأمن مسألة تشغيل وسلامة

01 OT وICS وIACS: ما الفرق؟

02 SCADA وPLC وBMS

03 Availability وSafety أولويات مختلفة

04 Zones and Conduits

05 Security Levels في IEC 62443

06 Legacy Systems والضوابط التعويضية

07 OT على مواقع الإنشاء

الباب 07 | 01

OT وICS وIACS: ما الفرق؟

مراجع الموضوع: [R02] [R12]

Operational Technology مصطلح واسع للأنظمة القابلة للبرمجة التي تتفاعل مع البيئة المادية. ICS أنظمة التحكم الصناعي، وIACS في IEC يشير إلى Industrial Automation and Control Systems.

في بيئة المقاولات والهندسة

هذه البيئات تختلف عن IT في دورات الحياة، السلامة، التوافر، البروتوكولات، واعتمادها على معدات ميدانية.

سؤال تحقق

هل صُنّف الأصل بدقة ضمن OT أو ICS أو IACS بحسب وظيفته؟

ما الذي يختلف عن IT؟

حدّد نوع النظام التشغيلي قبل الاستناد إلى متطلبات أمن صناعي مخصوصة.

الباب 07 | 02

SCADA وPLC وBMS

مراجع الموضوع: [R02] [R18]

SCADA للإشراف وجمع البيانات والتحكم الموزع؛ PLC متحكم منطقي قابل للبرمجة؛ BMS نظام إدارة المبنى لمراقبة/تحكم أنظمة مثل HVAC والطاقة.

في بيئة المقاولات والهندسة

وجود هذه الأنظمة لا يعني أنها متصلة بالإنترنت، لكن اتصالها بالشبكات أو الموردين أو الإدارة يخلق مسارات يجب فهمها.

سؤال تحقق

هل موثقة علاقات BMS وPLC وSCADA بالشبكات وبالموردين؟

ما الذي يختلف عن IT؟

اربط حماية أنظمة المبنى والتحكم بسلامة التشغيل وتوافر الخدمة.

الباب 07 | 03

أولويات مختلفة Safety وAvailability

مراجع الموضوع: [R02] [R12]

في OT قد يؤدي التوقف إلى فقد وظيفة مادية أو خطر سلامة، ولذلك لا يُطبّق إجراء أمني دون فهم أثره التشغيلي.

في بيئة المقاولات والهندسة

إعادة تشغيل جهاز لإتمام تحديث قد تكون بسيطة في IT وغير مقبولة أثناء عملية حرجة في OT.

سؤال تحقق

هل قُيّم أثر عزل نظام التشغيل أو تحديثه على الأشخاص والمعدات؟

ما الذي يتغير في القرار؟

نسّق الضابط الأمني مع متطلبات السلامة وعدم تعطيل العملية المادية.

الباب 07 | 04

Zones and Conduits

مراجع الموضوع: [R10] [R11]

IEC 62443-3-2 يطرح تقسيم النظام إلى Zones وأقنية اتصال Conduits، ثم تقييم مخاطر كل منطقة ومسار وتحديد مستوى أمان مستهدف.

في بيئة المقاولات والهندسة

الهدف ليس رسمًا هندسيًا جميلًا، بل جعل الحدود والثقة والتدفقات قابلة للتقييم والضبط.

سؤال تحقق

هل توجد حدود اتصال موثقة بين المناطق مع ضوابط لكل مسار؟

ما الذي يتغير في القرار؟

قسّم نظام التحكم إلى مناطق ووسائط اتصال على أساس تحليل المخاطر.

الباب 07 | 05

Security Levels في IEC 62443

مراجع الموضوع: [R11]

IEC 62443-3-3 يربط المتطلبات التقنية بمستويات أمان وقدرات النظام. لا ينبغي استخدام "SL" كتقييم تسويقي دون فهم النظام محل الدراسة والمتطلبات المستهدفة.

في بيئة المقاولات والهندسة

المعايير تساعد على لغة مشتركة بين المالك والمصمم والمتكامل والمورد.

سؤال تحقق

هل استُخدمت مستويات IEC 62443 في سياق تقييم موثق لا كوصف تسويقي؟

ما الذي يتغير في القرار؟

اربط مستويات الأمن المستهدفة بمتطلبات النظام والخطر المقيم.

الباب 07 | 06

Legacy Systems والضوابط التعويضية

مراجع الموضوع: [R02] [R12]

قد يعيش IACS أكثر من عشرين عامًا، وتوجد مكونات قديمة غير مدعومة لا يمكن ترقيعها بسهولة. IEC 62443-2-1:2024 يعترف بهذه الحقيقة التشغيلية.

في بيئة المقاولات والهندسة

العزل، allowlisting، تقليل الوصول، مراقبة الشبكة، وإدارة التغيير قد تصبح ضوابط تعويضية عندما يتعذر التحديث.

سؤال تحقق

هل سُجلت الأنظمة غير المدعومة مع خطة عزل ومراقبة ومسؤول محدد؟

ما الذي يتغير في القرار؟

عوّض قصور الأجهزة القديمة بضوابط محيطة دون تعريض التشغيل للخطر.

الباب 07 | 07

OT على مواقع الإنشاء

مراجع الموضوع: [R17] [R18]

الأبحاث في مواقع البناء تشير إلى نمو استخدام معدات روبوتية ومستقلة ومتحكم بها عن بعد، ما يضيف عواقب سلامة إلى الضعف السيبراني.

في بيئة المقاولات والهندسة

التقييم يجب أن يجمع الأمن والسلامة والتشغيل، لا أن ينسخ قائمة ضوابط مكتبية.

سؤال تحقق

هل يتضمن التقييم أثر فقد الاتصال أو تعديل الأوامر على السلامة؟

ما الذي يختلف عن IT؟

أدخل المعدات الروبوتية والمتحكم بها عن بعد في حصر أصول الموقع.

الباب 08

BIM وCDE والتوأم الرقمي

المعلومة الهندسية أصبحت أصلًا متصلًا

01 BIM: النموذج ليس ملفًا فقط
02 CDE: بيئة البيانات المشتركة
03 ISO 19650-5 وSecurity-Minded Approach
04 الملكية الفكرية والمعلومات التجارية
05 Digital Twin
06 IoT وSensors وDrones
07 الأمن في التسليم Handover

الباب 08 | 01

BIM: النموذج ليس ملفًا فقط

مراجع الموضوع: [R09]

Building Information Modelling هو منهج لإدارة المعلومات والنماذج عبر دورة الأصل، وليس مجرد نموذج ثلاثي الأبعاد.

في بيئة المقاولات والهندسة

قيمة BIM ترتبط بسلامة المعلومات، من يغيرها، كيف تعتمد، ومن يستطيع الوصول إليها.

سؤال تحقق

هل تضبط المؤسسة اعتماد النماذج وصلاحياتها عبر دورة المشروع؟

ما قيمة سلامة المعلومة؟

عامل BIM باعتباره عملية لإدارة معلومات الأصل لا ملف نموذج منفردًا.

الباب 08 | 02

CDE: بيئة البيانات المشتركة

مراجع الموضوع: [R09]

Common Data Environment مفهوم لإدارة وتبادل معلومات المشروع ضمن عملية ومنصة/منصات منظمة. الأمن فيها يشمل الأدوار، الصلاحيات، سير الاعتماد، السجلات، والمشاركة الخارجية.

في بيئة المقاولات والهندسة

المشكلة لا تحل بشراء منصة؛ يجب ضبط العملية والمسؤوليات.

سؤال تحقق

هل تميز CDE بين النسخ الجاري العمل عليها والنسخ المعتمدة للنشر؟

ما قيمة سلامة المعلومة؟

اربط أدوار بيئة البيانات المشتركة بمراحل الاعتماد وتبادل النسخ.

الباب 08 | 03

ISO 19650-5 وSecurity-Minded Approach

مراجع الموضوع: [R09]

ISO 19650-5 يحدد مبادئ ومتطلبات نهج واعٍ بالأمن لإدارة المعلومات الحساسة في BIM والبيئة المبنية عبر دورة الحياة.

في بيئة المقاولات والهندسة

الفكرة المحورية هي التناسب: تحديد الحساسية والمخاطر ثم تطبيق ما يلزم، لا حماية كل شيء بأقصى مستوى.

سؤال تحقق

هل استُخدمت مبادئ ISO 19650-5 بصورة متناسبة مع حساسية المشروع؟

ما الذي يتغير في القرار؟

حدد المعلومات الحساسة في BIM قبل فرض ضوابط تداولها.

الباب 08 | 04

الملكية الفكرية والمعلومات التجارية

مراجع الموضوع: [R08] [R09]

النماذج والتصميمات والتسعير والأساليب التنفيذية قد تحمل ملكية فكرية أو ميزة تنافسية. لذلك يتداخل أمن المعلومات مع السرية التعاقدية والحقوق.

في بيئة المقاولات والهندسة

التصنيف والوصول والمشاركة الخارجية والاحتفاظ يجب أن يراعي هذه القيمة.

سؤال تحقق

هل يعرف كل طرف حدود استخدام الملفات والمعلومات التجارية المستلمة؟

ما الذي يتغير في القرار؟

افصل تداول التصميمات والتسعير والابتكارات بما يحمي الحقوق التعاقدية.

الباب 08 | 05

Digital Twin

مراجع الموضوع: [R17]

التوأم الرقمي Digital Twin تمثيل رقمي مرتبط بكيان أو عملية فعلية بدرجات مختلفة من الاتصال والتحديث. كلما زاد الاتصال بالبيانات الحية زادت فرص القيمة وكذلك المخاطر السيبرانية الفيزيائية.

في بيئة المقاولات والهندسة

الأبحاث الحديثة ترى التوأم الرقمي في المقاولات تحديًا اجتماعيًا وتقنيًا وحوكميًا، لا منتجًا تقنيًا منفردًا.

سؤال تحقق

هل يُعرف مصدر بيانات التوأم ومن يمكنه تغييرها أو إعادة استخدامها؟

ما الذي يتغير في القرار؟

وازن فوائد التوأم الرقمي مع أخطار الاتصالات والبيانات الحية.

الباب 08 | 06

IoT وSensors وDrones

مراجع الموضوع: [R17] [R18]

أجهزة الاستشعار والكاميرات والطائرات المسيرة تضيف رؤية للموقع، لكنها تضيف هويات وبرمجيات ثابتة واتصالات وبيانات ومزودين.

في بيئة المقاولات والهندسة

إدارة هذه الأصول تحتاج inventory، تحديثات، إعدادات آمنة، فصلًا شبكيًا، وقرارًا حول دورة حياتها بعد المشروع.

سؤال تحقق

هل توجد سياسة تحديث وصلاحيات واتلاف للبيانات التي تجمعها الأجهزة؟

ما الذي يتغير في القرار؟

أدخل الحساسات والطائرات المسيّرة ضمن جرد الهويات والاتصالات والبيانات.

الباب 08 | 07

الأمن في التسليم Handover

مراجع الموضوع: [R09] [R02]

تسليم أصل رقمي لا يقتصر على ملفات as-built؛ قد يشمل حسابات إدارية وشهادات ومفاتيح وأجهزة وأنظمة BMS/OT ووثائق شبكة.

في بيئة المقاولات والهندسة

Cyber Handover المنضبط يضمن انتقال الملكية والصلاحيات والوثائق وإغلاق وصول المقاول والمورد في الوقت الصحيح.

سؤال تحقق

هل يتضمن محضر تسليم المشروع حسابات الإدارة والشهادات وبيانات الشبكات؟

ما الذي يتغير في القرار؟

اجعل التسليم الفني إغلاقًا آمنًا للحسابات والاتصالات والمفاتيح أيضًا.

الباب 09

مشهد التهديدات

من التصيد إلى الابتزاز وتعطيل المشروع

01 Social وPhishing Engineering

02 Account وCredential Theft Takeover

03 Data وRansomware Extortion

04 استغلال الثغرات

05 Third-Party Compromise

06 Human Error وInsider

07 AI كعامل تسريع لا كبديل للأساسيات

الباب 09 | 01

Social Engineering وPhishing

مراجع الموضوع: [R13] [R20]

التصيد يحاول دفع المستخدم للكشف عن اعتماداته أو تنفيذ إجراء ضار. Social Engineering أوسع ويستغل الثقة والسلوك والسياق.

في بيئة المقاولات والهندسة

في المشاريع قد يستغل المهاجم أسماء الموردين والفواتير والتغييرات والضغط الزمني لجعل الرسالة مقنعة.

سؤال تحقق

هل يستطيع الموظف التحقق من تغيير حساب مورد أو تعليمات دفع عاجلة؟

ما الذي يتغير في القرار؟

اربط التوعية بالتصيد بمسارات الإبلاغ والتحقق من الطلبات المالية.

الباب 09 | 02

Account Takeover وCredential Theft

مراجع الموضوع: [R05] [R20]

سرقة الاعتمادات تمنح المهاجم وصولًا يبدو مشروعًا. لذلك تصبح MFA والمراقبة والسلوك الشاذ وتقليل الامتيازات وسائل مهمة.

في بيئة المقاولات والهندسة

الحساب الشرعي المسروق قد يتجاوز كثيرًا من الدفاعات المبنية على "داخل/خارج الشبكة".

سؤال تحقق

هل يمكن كشف دخول غير مألوف وإبطال الجلسات والاعتمادات المسروقة؟

ما الذي يتغير في القرار؟

راقب سرقة الهوية من خلال المصادقة وسلوك الدخول وإدارة الجلسات.

الباب 09 | 03

Ransomware وData Extortion

مراجع الموضوع: [R06] [R14]

Ransomware قد يشفر البيانات، وقد يسبق التشفير سرقة معلومات للابتزاز. NIST حدّث في 2026 Community Profile مخصصًا لإدارة خطر ransomware عبر وظائف CSF 2.0.

في بيئة المقاولات والهندسة

الاستعداد يتطلب حماية وكشفًا واستجابة وتعافيًا؛ النسخ وحدها لا تعالج تسريب البيانات.

سؤال تحقق

هل توجد خطة استعادة واتصال قانوني وتشغيلي عند ابتزاز البيانات؟

ما الذي يتغير في القرار؟

أدر خطر الفدية بوصفه تعطيلاً للوظيفة واحتمال تسريب معلومات معًا.

الباب 09 | 04

استغلال الثغرات

مراجع الموضوع: [R16] [R20]

ثغرة قابلة للاستغلال على أصل مكشوف قد تصبح نقطة دخول. CISA KEV يساعد على إعطاء وزن أعلى للثغرات المعروفة بالاستغلال.

في بيئة المقاولات والهندسة

تقارير 2026 العالمية تشير إلى تصاعد استغلال الثغرات كنقطة دخول؛ ينبغي استخدام هذه البيانات كمؤشر اتجاه لا كاحتمال خاص بقطاع البناء.

سؤال تحقق

هل تُطابق أنظمة المؤسسة دورياً مع قائمة KEV بحسب انكشافها؟

ما الذي يتغير في القرار؟

قدّم الثغرات المستغلة والمعرّضة للإنترنت في خطة المعالجة.

الباب 09 | 05

Third-Party Compromise

مراجع الموضوع: [R04] [R20]

اختراق مورد يمكن أن يصل إلى عدة عملاء عبر حسابات أو برمجيات أو قنوات دعم. كلما توسعت سلسلة الإمداد زادت أهمية معرفة الاتصالات والاعتماديات.

في بيئة المقاولات والهندسة

تقارير DBIR 2026 أظهرت نموًا قويًا في دور الطرف الثالث على مستوى عالمي؛ لا يجوز تحويل النسبة العالمية إلى تقدير مباشر لمشروع محدد.

سؤال تحقق

هل يمكن حصر كل الأنظمة التي يصل إليها المورد وإلغاء دخوله مركزيًا؟

ما الذي يتغير في القرار؟

عامل وصول المورد المسروق كتهديد محتمل لعدة مشاريع مترابطة.

الباب 09 | 06

Human Error و Insider

مراجع الموضوع: [R08] [R17]

التهديد الداخلي قد يكون خبيثًا أو غير مقصود. الخطأ البشري، المشاركة الخاطئة، سوء الإعداد، أو استخدام أدوات غير معتمدة كلها مسارات واقعية.

في بيئة المقاولات والهندسة

الحل ليس "التوعية" وحدها؛ بل تصميم عمليات تقلل فرص الخطأ وتجعله قابلاً للاكتشاف والتصحيح.

سؤال تحقق

هل تتوافر آلية لتصحيح مشاركة ملف أو إعداد غير آمن سريعًا؟

ما الذي يتغير في القرار؟

عالج الخطأ البشري عبر تصميم إجراءات واضحة ومراجعة صلاحيات لا لوم فردي.

الباب 09 | 07

AI كعامل تسريع لا كبديل للأساسيات

مراجع الموضوع: [R20] [R21]

تقارير 2026 تُظهر أن الذكاء الاصطناعي يسرع بعض الهجمات ويزيد قدرة الانتحال والأتمتة. وفي المقابل يستخدم المدافعون AI للأمن.

في بيئة المقاولات والهندسة

لا ينبغي أن يطغى خطاب AI على الأساسيات: هوية قوية، ترقية، نسخ، تقسيم، مراقبة، استجابة. IBM 2026 يقدّم مؤشرات عالمية عن التكلفة والهجمات المدعومة بالذكاء الاصطناعي، لكنها ليست خاصة بالإنشاءات.

سؤال تحقق

هل قيّمت المؤسسة كيف يؤثر انتحال الهوية المعزز بالذكاء الاصطناعي؟

ما الذي يتغير في القرار؟

لا تجعل حلول الذكاء الاصطناعي بديلاً عن الجرد والمصادقة والمراقبة.

YK7
منصة الرصد الاستراتيجي

الباب 10

الحوكمة والأطر والمعايير

كيف نستخدم المرجع دون تحويله إلى قائمة جامدة؟

01 Govern في CSF 2.0

02 وظائف CSF الست

03 ISO/IEC 27001 وISMS

04 ISO/IEC 27002

05 IEC 62443 للIACS

06 Zero Trust

07 CPGs: خط أساس عملي

الباب 10 | 01

Govern في CSF 2.0

مراجع الموضوع: [R01]

أضاف CSF 2.0 وظيفة Govern كوظيفة مستقلة، مؤكداً أن استراتيجية المخاطر والسياسات والأدوار وسلسلة الإمداد والإشراف أساس لبقية الوظائف.

في بيئة المقاولات والهندسة

الأمن الذي لا يملك قرارًا وتمويلًا ومسؤولية واضحة يبقى نشاطًا تقنيًا متقطعًا.

سؤال تحقق

هل تعتمد الإدارة استراتيجية مخاطر سيبرانية وتراجع قراراتها؟

ما الذي يتغير في القرار؟

اربط وظيفة Govern بسلطات الاعتماد والمساءلة وتخصيص الموارد.

الباب 10 | 02

وظائف CSF الست

مراجع الموضوع: [R01]

Govern, Identify, Protect, Detect, Respond, Recover هي نتائج عالية المستوى لإدارة الخطر. CSF لا يفرض طريقة واحدة للتنفيذ بل لغة مشتركة وأهدافًا.

في بيئة المقاولات والهندسة

يمكن للمؤسسة بناء Current Profile وTarget Profile وتحديد الفجوات والأولويات.

سؤال تحقق

هل توجد نتائج وأدلة تعكس الحوكمة والتعرف والحماية والكشف والاستجابة والتعافي؟

ما الذي يتغير في القرار؟

استخدم وظائف CSF الست لتنظيم نتائج العمل لا فرض أدوات بعينها.

الباب 10 | 03

ISMS وISO/IEC 27001

مراجع الموضوع: [R07]

ISO/IEC 27001:2022 يحدد متطلبات نظام إدارة أمن المعلومات ISMS. الفكرة ليست "شهادة" فقط؛ بل نظام لإدارة المخاطر والسياسات والأدوار والتحسين المستمر.

في بيئة المقاولات والهندسة

نطاق ISMS يجب أن يكون محددًا، وعدم وجود شهادة لا يعني عدم وجود ممارسات أمنية، كما أن وجودها لا يثبت خلو المؤسسة من الحوادث.

سؤال تحقق

هل تُراجع مخاطر أمن المعلومات والإجراءات والمسؤوليات بصورة دورية؟

ما الذي يتغير في القرار؟

عامل نظام إدارة أمن المعلومات دورة تحسين لا شهادة معلقة.

الباب 10 | 04

ISO/IEC 27002

مراجع الموضوع: [R07] [R08]

ISO/IEC 27002:2022 يقدم إرشادات بشأن ضوابط أمن المعلومات؛ وهو مرجع للممارسات وليس معيار متطلبات شهادة مستقلًا مثل 27001.

في بيئة المقاولات والهندسة

التمييز يمنع استخدام أرقام المعايير بطريقة دعائية غير دقيقة.

سؤال تحقق

هل ترتبط ضوابط ISO/IEC 27002 بالمخاطر المحددة وأسباب اختيارها؟

ما الذي يتغير في القرار؟

افصل بين متطلبات النظام الإداري وإرشادات اختيار الضوابط وتنفيذها.

الباب 10 | 05

IEC 62443 للـIACS

مراجع الموضوع: [R10] [R11] [R12]

سلسلة IEC 62443 تتعامل مع أمن الأتمتة والتحكم الصناعي من زوايا متعددة تشمل مالك الأصل، التصميم، الأنظمة والمكونات.

في بيئة المقاولات والهندسة

في بيئة OT، المرجع الأنسب غالبًا أكثر تخصصًا من تطبيق ضوابط IT حرفيًا.

سؤال تحقق

هل حددت المؤسسة المعيار الجزئي المناسب قبل الادعاء بالامتثال؟

ما الذي يتغير في القرار؟

اختر جزء IEC 62443 بحسب دور المالك والمورد والنظام محل الدراسة.

الباب 10 | 06

Zero Trust

مراجع الموضوع: [R05]

Zero Trust لا يعني "لا نثق بأحد" بالمعنى الاجتماعي؛ بل نقل الحماية من الاعتماد على موقع الشبكة إلى التحقق المستمر من الوصول إلى الموارد وفق الهوية والسياق والسياسة.

في بيئة المقاولات والهندسة

يمكن تبني مبادئه تدريجيًا ولا يلزم مشروع ضخم باسم Zero Trust.

سؤال تحقق

هل تقيّم صلاحيات الوصول للموارد دون الاعتماد على موقع الشبكة وحده؟

ما الذي يتغير في القرار؟

تحقق من هوية المستخدم والجهاز والسياق قبل كل وصول حساس.

الباب 10 | 07

CPGs: خط أساس عملي

مراجع الموضوع: [R13]

CISA Cross-Sector CPGs تقدم مجموعة طوعية محدودة من ممارسات عالية الأثر لـIT وOT، مفيدة كبداية للمؤسسات التي تحتاج ترتيب الأولويات.

في بيئة المقاولات والهندسة

هي ليست بديلاً عن تقييم الخطر أو المعايير القطاعية، لكنها تساعد على "أين نبدأ؟".

سؤال تحقق

هل حُددت مسؤولية وتاريخ إنجاز لكل إجراء أساسي مختار؟

ما الذي يتغير في القرار؟

استخدم CPGs لترتيب خط أساس محدود وعالي الأثر وفق الحاجة.

الباب 11

الكشف والاستجابة والتعافي

الحادث لا يبدأ عند اكتشافه ولا ينتهي بإغلاق التذكرة

01 Detection Engineering
02 Incident vs Event
03 الاستجابة :SP 800-61 Rev.3 ضمن إدارة الخطر
04 Ransomware Playbook
05 Evidence وForensics
06 Cyber Recovery وDR وBCP
07 Tabletop Exercise

الباب 11 | 01

Detection Engineering

مراجع الموضوع: [R03]

الكشف الجيد يبدأ بسؤال: ما السلوك الذي نريد اكتشافه؟ وما البيانات اللازمة؟ ثم تبنى القاعدة والتنبيه والاختبار.

في بيئة المقاولات والهندسة

جمع كل السجلات دون حالات استخدام قد يزيد الضوضاء والتكلفة.

سؤال تحقق

هل جُرّبت قاعدة الكشف وأثبتت تنبيهًا مفيدًا بلا ضجيج مفرط؟

ما الذي يتغير في القرار؟

صمّم حالات الكشف حول سلوك تهديد معروف وربطها بسجلات قابلة للتحليل.

الباب 11 | 02

Incident vs Event

مراجع الموضوع: [R03]

Event حدث مسجل؛ Incident حادث يؤثر أو يهدد أهداف الأمن ويتطلب استجابة. ليس كل تنبيه حادثًا، لكن سلسلة أحداث قد تكشف حادثًا.

في بيئة المقاولات والهندسة

التعريف الداخلي يساعد على تحديد متى تُصعّد الحالة ومن يُبلغ.

سؤال تحقق

هل توجد عتبات تصعيد واضحة مرتبطة بأثر الحدث على المشروع؟

ما الذي يتغير في القرار؟

افصل بين الحدث المسجّل والحادث الذي يستلزم قرار استجابة.

الباب 11 | 03

SP 800-61 Rev.3: الاستجابة ضمن إدارة الخطر

مراجع الموضوع: [R03]

مراجعة 2025 من NIST أعادت وضع Incident Response داخل جميع وظائف CSF 2.0، بدل التعامل معه كحلقة تقنية منفصلة بعد وقوع الحادث.

في بيئة المقاولات والهندسة

الاستعداد يبدأ من الحوكمة والجرد والحماية والمراقبة قبل لحظة الاستجابة.

سؤال تحقق

هل تتوزع مهام الاستجابة والتعافي والتعلّم عبر فرق المؤسسة؟

ما الذي يتغير في القرار؟

ادمج تخطيط الحوادث والاستجابة ضمن إدارة المخاطر والحوكمة.

الباب 11 | 04

Ransomware Playbook

مراجع الموضوع: [R06] [R14]

Playbook يحدد أدوارًا وخطوات واتصالات وقرارات لحالة محددة مثل ransomware: عزل، حفظ أدلة، تقييم نطاق، استمرارية، إخطار، تعافي.

في بيئة المقاولات والهندسة

يجب أن يُختبر في تمرين، لأن وقت الحادث ليس وقت اكتشاف أرقام الاتصال أو صلاحيات القرار.

سؤال تحقق

هل اختُبر سيناريو الفدية مع فريق التشغيل والشؤون القانونية؟

ما الذي يتغير في القرار؟

حدّد مسبقًا المسؤول عن العزل وحفظ الأدلة والتواصل واستمرار الوظائف.

الباب 11 | 05

Evidence وForensics

مراجع الموضوع: [R03]

التحقيق الرقمي يحتاج حفظ الأدلة وسلسلة الحيازة والسياق الزمني. لا ينبغي للموظف غير المخول "استكشاف" جهاز بطريقة تغير الأدلة عند حادث حساس.

في بيئة المقاولات والهندسة

خطة الاستجابة تحدد متى تُستدعى خبرة خارجية قانونية أو جنائية رقمية.

سؤال تحقق

هل تحدد الإجراءات الأشخاص المخولين بجمع الأدلة وتوثيقها؟

ما الذي يتغير في القرار؟

احمِ سلسلة حيازة الأدلة وامنع العبث أثناء الاستجابة للحوادث الحساسة.

الباب 11 | 06

BCP وDR وCyber Recovery

مراجع الموضوع: [R03] [R06]

Business Continuity يحافظ على الوظائف الحرجة؛ Disaster Recovery يعيد الأنظمة؛ Cyber Recovery يركز على التعافي من هجوم قد يستهدف الهوية والنسخ والبنية نفسها.

في بيئة المقاولات والهندسة

RTO يحدد زمن الاستعادة المستهدف، وRPO يحدد مقدار البيانات المقبول فقده زمنيا.

سؤال تحقق

هل تستطيع المؤسسة استعادة وظيفة حرجة إذا تضررت النسخ والحسابات؟

ما الذي يتغير في القرار؟

اعتمد خطط استمرارية وتعافٍ متكاملة تشمل الهوية والنسخ والأنظمة.

الباب 11 | 07

Tabletop Exercise

مراجع الموضوع: [R03] [R14]

التمرين المكتبي يناقش سيناريو حادث دون تنفيذ تغييرات على الأنظمة. قيمته في اختبار القرار والتواصل والاعتماديات والفجوات.

في بيئة المقاولات والهندسة

سيناريو جيد لقطاع المقاولات: تشفير منصة ملفات مشروع مع حساب مورد مشتبه به قبل موعد تسليم حرج.

سؤال تحقق

هل وثّق التمرين فجوات المسؤولية والاتصال ومواعيد معالجتها؟

ما الذي يتغير في القرار؟

اختبر التنسيق بين القرار الإداري والتقني والقانوني في تمرين مكتبي.

الباب 12

النضج والقياس وخارطة الطريق

من معرفة الخطر إلى تحسين قابل للقياس

01 Current وTarget Profiles
02 KPI وKRI
03 قياس الوعي والثقافة
04 الأمن داخل إدارة المشروع
05 خارطة 12-24 شهراً
06 نموذج YK7 السباعي للقراءة المؤسسية السيبرانية
07 من الرصد إلى القرار

الباب 12 | 01

Current وTarget Profiles

مراجع الموضوع: [R01]

يمكن استخدام CSF 2.0 لوصف الوضع الحالي Current Profile والنتائج المستهدفة Target Profile، ثم تحديد الفجوات حسب الأولوية.

في بيئة المقاولات والهندسة

لا يعني النضج الوصول إلى أعلى مستوى في كل شيء؛ الهدف تحقيق مستوى يتناسب مع الخطر والموارد والالتزامات.

سؤال تحقق

هل يمكن تفسير اختيار المستوى المستهدف بالأثر والمخاطر والموارد؟

ما الذي يتغير في القرار؟

استخدم ملف الوضع الحالي والمستهدف لتحديد فجوات مرتبطة بالأولويات.

الباب 12 | 02

KPI وKRI

مراجع الموضوع: [R01]

KPI مؤشر أداء يراقب جودة تنفيذ نشاط، أما KRI مؤشر مخاطر يساعد على رؤية التعرض. مثال KPI: زمن إغلاق حسابات المغادرين؛ KRI: عدد الحسابات الخارجية ذات الوصول الحرج غير المستخدمة.

في بيئة المقاولات والهندسة

المؤشر الجيد يدفع قرارًا؛ المؤشر الذي لا يغير شيئًا قد يكون عبئًا تقريريًا.

سؤال تحقق

هل يستطيع مجلس الإدارة تفسير ما يعنيه تغير KPI أو KRI؟

ما الذي يتغير في القرار؟

افصل بين مؤشر تنفيذ الضابط ومؤشر التعرض أو الخطر المتبقي.

الباب 12 | 03

قياس الوعي والثقافة

مراجع الموضوع: [R08] [R17]

عدد من حضر الدورة لا يثبت تغير السلوك. يمكن قياس الإبلاغ عن التصيد، أخطاء المشاركة، الالتزام بإجراءات الوصول، ونوعية الحوادث البشرية.

في بيئة المقاولات والهندسة

الثقافة الأمنية تتأثر بالقيادة وسهولة العملية والحوافز بقدر المحتوى التدريبي.

سؤال تحقق

هل تغيّر زمن الإبلاغ عن التصيد أو أخطاء المشاركة بعد التدريب؟

ما الذي يتغير في القرار؟

اقس أثر التدريب في السلوك والإبلاغ لا في عدد الشهادات والحضور.

الباب 12 | 04

الأمن داخل إدارة المشروع

مراجع الموضوع: [R09] [R02]

إدخال الأمن في Project Gate يقلل التكلفة المتأخرة: متطلبات قبل التعاقد، تصميم أمني، مراجعة قبل التشغيل، واختبار تسليم أمني.

في بيئة المقاولات والهندسة

Security by Design في المشاريع يعني أن السؤال الأمني يدخل القرار في الوقت الذي يمكن تغييره فيه، لا بعد تركيب النظام.

سؤال تحقق

هل تُراجع المخاطر السيبرانية قبل كل قرار شراء أو تشغيل أو تسليم؟

ما الذي يتغير في القرار؟

أدرج متطلبات الأمن في بوابات المشروع من التعاقد حتى التسليم.

الباب 12 | 05

خارطة 12-24 شهراً

مراجع الموضوع: [R01] [R13]

الخارطة العملية تبدأ بالأساسيات: الجرد، الهوية، النسخ، الموردون، التسجيل، الاستجابة؛ ثم تتحرك إلى تحسينات أعمق مثل segmentation وPAM وOT monitoring وفق الخطر.

في بيئة المقاولات والهندسة

الترتيب أهم من كثرة المبادرات؛ عشرون مشروعًا متزامنًا بلا قدرة تنفيذ قد يضعف النتيجة.

سؤال تحقق

هل لخارطة الطريق مسؤوليات ومواعيد ومؤشرات تحقق وميزانية؟

ما الذي يتغير في القرار؟

ابدأ بخط أساس أولوي ثم وسّع الضوابط وفق الموارد ومخاطر التشغيل.

الباب 12 | 06

نموذج YK7 السباعي للقراءة المؤسسية السيبرانية

مراجع الموضوع: [R22] [R01] [R02]

إطار إجرائي من بناء YK7: السياق، الأصول، الثقة والوصول، الاستمرارية، الطرف الثالث، IT/OT، وجودة القرار. يستخدم لتنظيم الأسئلة وربط التقنية بالمؤسسة.

في بيئة المقاولات والهندسة

هو ليس معيارًا دوليًا ولا بديلاً عن NIST أو ISO أو IEC؛ بل أداة قراءة تستفيد منها وتربطها بمنهج الرصد المؤسسي.

سؤال تحقق

هل ترتبط العدسات السبع بأدلة فعلية وقرار ذي مسؤول محدد؟

ما الذي يتغير في القرار؟

استخدم النموذج السباعي لتنظيم الأسئلة ولا تقدمه بديلاً عن المعايير.

الباب 12 | 07

من الرصد إلى القرار

مراجع الموضوع: [R01] [R22]

الرصد الجيد يميز بين حقيقة مثبتة، مؤشر يحتاج تحققًا، استنتاج تحليلي، وتوصية. غياب الدليل لا يساوي دليل الغياب.

في بيئة المقاولات والهندسة

هذه القاعدة تحمي التقارير العامة من إصدار أحكام عن SOC أو SIEM أو ISO أو مستوى النضج دون بيانات داخلية.

سؤال تحقق

هل هناك دليل مستقل على كل حكم يتعلق بنضج جهة أو امتثالها؟

ما الذي يتغير في القرار؟

افصل في التقرير بين الوقائع والمؤشرات والاستنتاجات والتوصيات.

الملاحق العلمية

من القراءة إلى الرجوع السريع

الصفحات التالية تحول المرجع إلى أداة استخدام: تعريفات، اختصارات، مقارنات، قوائم فحص، ثم قائمة المراجع الكاملة.

المصطلح الدقيق يقلل سوء الفهم؛ وقائمة الفحص الجيدة تفتح سؤالًا، لكنها لا تستبدل التقييم المهني.

قاموس المصطلحات | 01-04

المصطلح ومعناه في هذا الكتاب

سطح الهجوم
Attack Surface

مجموع نقاط التفاعل الممكن استغلالها للوصول أو التأثير في النظام.

مستقر

الأصل
Asset

مورد أو معلومات أو نظام أو قدرة لها قيمة للمؤسسة وتحتاج حماية.

مستقر

التهديد
Threat

سبب أو حدث محتمل يمكن أن يسبب ضررًا لأصل أو عملية.

مستقر

السطح السيبراني للمشروع
Project Cyber Surface

صياغة إجرائية في YK7 تجمع أصول المشروع وهوياته واتصالاته وموردیه وأنظمته التشغيلية في صورة واحدة للمخاطر.

YK7 إجرائي

قاموس المصطلحات | 05-08

المصطلح ومعناه في هذا الكتاب

الخطر

Risk

أثر عدم اليقين على الأهداف، وفي الأمن يرتبط باحتمال/ظروف الحدث وأثره وسياقه.

مستقر

الثغرة

Vulnerability

ضعف يمكن استغلاله أو إساءة استخدامه.

مستقر

السرية

Confidentiality

قصر الوصول إلى المعلومات على المصرح لهم.

مستقر

الضابط

Control

إجراء إداري أو تقني أو مادي لتعديل مستوى الخطر.

مستقر

قاموس المصطلحات | 09-12

المصطلح ومعناه في هذا الكتاب

التوافر
Availability

إتاحة المعلومات أو الوظيفة للمستخدم/العملية المصرح لها عند الحاجة.

مستقر

السلامة المعلوماتية
Integrity

الحفاظ على صحة المعلومات واكتمالها ومنع التغيير غير المصرح.

مستقر

إدارة الهوية والوصول
IAM

إدارة دورة حياة الهويات والمصادقة والتفويض والمراجعة والإلغاء.

مستقر

المرونة السيبرانية
Cyber Resilience

القدرة على الاستمرار والاستجابة والتعافي رغم الاضطراب السيبراني.

مستقر

قاموس المصطلحات | 13-16

المصطلح ومعناه في هذا الكتاب

أقل امتياز

Least Privilege

منح أقل صلاحية لازمة لأداء المهمة ولمدة الحاجة.

مستقر

المصادقة متعددة العوامل

MFA

استخدام عاملين أو أكثر من فئات مصادقة مستقلة لرفع الثقة في الهوية.

مستقر

إدارة الوصول المميز

PAM

ضبط الحسابات والصلاحيات ذات الامتياز العالي وإدارتها ومراقبتها.

مستقر

الدخول الموحد

SSO

آلية تسمح باستخدام جلسة/هوية واحدة للوصول إلى عدة تطبيقات وفق سياسة مركزية.

مستقر

قاموس المصطلحات | 17-20

المصطلح ومعناه في هذا الكتاب

منطقة منزوعة السلاح

DMZ

شبكة وسيطة تفصل خدمات تحتاج اتصالًا عبر حدود ثقة مختلفة.

مستقر

تقسيم الشبكة

Network Segmentation

فصل الشبكة إلى مناطق مع ضبط المرور بينها لتقليل الانتشار والحركة الجانبية.

مستقر

انعدام الثقة

Zero Trust

نموذج يركز على حماية الموارد والتحقق المستمر بدل افتراض الثقة بسبب موقع الشبكة.

مستقر

شبكة خاصة افتراضية

VPN

قناة منطقية محمية تسمح باتصال بعيد أو ربط شبكات عبر بنية غير موثوقة.

مستقر

قاموس المصطلحات | 21-24

المصطلح ومعناه في هذا الكتاب

إدارة معلومات وأحداث الأمن
SIEM

منصة تجمع وتحلل سجلات وأحداث أمنية لدعم الكشف والتحقيق.

مستقر

السجل
Log

تسجيل زمني لحدث أو نشاط في نظام أو جهاز أو تطبيق.

مستقر

مركز عمليات الأمن
SOC

وظيفة/فريق لمراقبة الأمن وتحليل التنبيهات والاستجابة وفق نموذج تشغيلي.

مستقر

كشف واستجابة الطرفيات
EDR

قدرات لرصد سلوك أجهزة الطرفيات والتحقيق والاستجابة.

مستقر

قاموس المصطلحات | 25-28

المصطلح ومعناه في هذا الكتاب

التصحيح
Patch

تحديث يعالج خطأ أو ثغرة أو يحسن برنامجًا/نظامًا.

مستقر

إدارة الثغرات
Vulnerability Management

دورة مستمرة لاكتشاف الثغرات وتقييمها وترتيبها ومعالجتها والتحقق.

مستقر

التصيد
Phishing

خداع المستخدم عبر رسالة/موقع/اتصال للحصول على اعتماد أو إجراء ضار.

مستقر

برنامج فدية
Ransomware

هجوم قد يشفر البيانات أو يعطلها ويطلب فدية، وقد يقترن بسرقة البيانات والابتزاز.

مستقر

قاموس المصطلحات | 29-32

المصطلح ومعناه في هذا الكتاب

النسخ الاحتياطي
Backup

نسخة منفصلة مصممة لدعم الاستعادة بعد فقد أو تلف أو هجوم.

مستقر

الهندسة الاجتماعية
Social Engineering

استغلال السلوك والثقة والسياق لخداع الأشخاص أو دفعهم إلى إجراء ضار.

مستقر

نقطة الاستعادة المستهدفة
RPO

الحد الزمني المقبول لفقد البيانات عند الاستعادة.

مستقر

زمن الاستعادة المستهدف
RTO

الزمن المستهدف لاستعادة خدمة/وظيفة بعد انقطاع.

مستقر

قاموس المصطلحات | 33-36

المصطلح ومعناه في هذا الكتاب

نظام تحكم صناعي

ICS

فئة أنظمة تستخدم لمراقبة/تحكم العمليات الصناعية.

مستقر

تقنية التشغيل

OT

أنظمة وأجهزة قابلة للبرمجة تتفاعل مع البيئة المادية أو تدير ما يتفاعل معها.

مستقر

SCADA

Supervisory Control and Data Acquisition

أنظمة إشراف وجمع بيانات وتحكم لعمليات موزعة.

مستقر

IACS

Industrial Automation and Control Systems

مصطلح شائع في IEC 62443 لأنظمة الأتمتة والتحكم الصناعي.

مستقر

قاموس المصطلحات | 37-40

المصطلح ومعناه في هذا الكتاب

BMS
Building Management System
نظام إدارة مبنى يراقب ويتحكم في خدمات مثل HVAC والطاقة وفق التصميم.
مستقر

PLC
Programmable Logic Controller
متحكم صناعي قابل للبرمجة لتنفيذ منطق تحكم في المعدات والعمليات.
مستقر

Zone
Zone
تجميع منطقي/مادي لأصول IACS لها متطلبات أمنية متقاربة وفق IEC 62443.
معياري

HMI
Human-Machine Interface
واجهة يتفاعل عبرها المشغل مع نظام أو عملية صناعية.
مستقر

قاموس المصطلحات | 41-44

المصطلح ومعناه في هذا الكتاب

BIM

Building Information Modelling

منهج لإدارة المعلومات والنماذج الرقمية للأصل المبني خلال دورة حياته.

مستقر

Conduit

Conduit

مسار اتصال بين Zones يُدار كجزء من تصميم الأمن في IEC 62443.

معياري

التوأم الرقمي

Digital Twin

تمثيل رقمي مرتبط بأصل/عملية فعلية بدرجات متفاوتة من الاتصال والتحديث.

مستقر

CDE

Common Data Environment

عملية وبيئة رقمية منظمة لإدارة ومشاركة معلومات المشروع.

مستقر

قاموس المصطلحات | 45-48

المصطلح ومعناه في هذا الكتاب

إنترنت الأشياء

IoT

شبكة أجهزة/حساسات متصلة تجمع أو تتبادل بيانات وقد تنفذ إجراءات.

مستقر

نظام سيبراني فيزيائي

CPS

نظام يدمج الحوسبة والاتصال مع عملية أو مكون مادي.

مستقر

الاستجابة للحوادث

Incident Response

قدرات وعمليات التحضير والكشف والتحليل والاستجابة والتعافي من الحوادث.

مستقر

سلسلة الإمداد السيبرانية

C-SCRM

إدارة مخاطر الأمن المرتبطة بالمنتجات والخدمات والموردين وسلسلة التوريد.

مستقر

قاموس المصطلحات | 49-52

المصطلح ومعناه في هذا الكتاب

التعافي من الكوارث

DR

خطط وإجراءات لاستعادة تقنيات وخدمات بعد اضطراب كبير.

مستقر

استمرارية الأعمال

BCP

تخطيط لاستمرار الوظائف الحرجة أثناء وبعد الاضطراب.

مستقر

مؤشر أداء

KPI

مقياس لمستوى أداء نشاط أو عملية.

مستقر

تمرين مكتبي

Tabletop Exercise

مناقشة منظمة لسيناريو حادث لاختبار القرار والأدوار والاتصالات دون تنفيذ حي.

مستقر

قاموس المصطلحات | 53-56

المصطلح ومعناه في هذا الكتاب

ملف الوضع الحالي
Current Profile

وصف نتائج الأمن الحالية باستخدام بنية CSF لتحديد موضع المؤسسة.

NIST

مؤشر مخاطر
KRI

مقياس يستخدم لرصد تغير التعرض أو مستوى الخطر.

مستقر

مستوى الأمن المستهدف
SL-T

مستوى أمان مستهدف في سياق Zone/Conduit لـIEC 62443 وفق تقييم المخاطر.

معياري

ملف الوضع المستهدف
Target Profile

وصف النتائج الأمنية التي تريد المؤسسة بلوغها وفق المخاطر والأولويات.

NIST

قاموس المصطلحات | 57-60

المصطلح ومعناه في هذا الكتاب

حركة جانبية

Lateral Movement

انتقال المهاجم من أصل إلى آخر داخل البيئة بعد نقطة الدخول الأولية.

مستقر

البيئة الموثوقة

Trust Boundary

حد يتغير عنده مستوى الثقة أو السياسة ويحتاج ضبطًا بين مناطق/موارد.

مستقر

سرّ تقني

Secret

معلومة مصادقة حساسة مثل مفتاح API أو كلمة مرور خدمة أو مفتاح خاص.

مستقر

حساب خدمي

Service Account

هوية تستخدمها خدمة أو تطبيق بدل مستخدم بشري.

مستقر

قاموس المصطلحات | 61-64

المصطلح ومعناه في هذا الكتاب

التشفير أثناء السكون
Encryption at Rest

حماية البيانات المخزنة على وسائط أو قواعد بيانات بالتشفير.

مستقر

التشفير أثناء النقل
Encryption in Transit

حماية البيانات وهي تنتقل عبر قناة اتصال باستخدام بروتوكولات تشفير.

مستقر

التسليم السيبراني
Cyber Handover

صياغة إجرائية لتنظيم انتقال الحسابات والمفاتيح والوثائق والأصول الرقمية والتشغيلية إلى المالك.

YK7 إجرائي

إغلاق المشروع السيبراني
Cyber Closeout

صياغة إجرائية لتنظيم إلغاء الوصول وسحب الأصول وتسليم الأسرار وأرشفة الأدلة عند انتهاء المشروع.

YK7 إجرائي

قاموس المصطلحات | 65-65

المصطلح ومعناه في هذا الكتاب

القراءة المؤسسية السيبرانية
Institutional Cyber Reading
مصطلح إجرائي في YK7 لربط السياق والأصول والثقة والاستمرارية والطرف الثالث وIT/OT بالقرار.
YK7 إجرائي

دليل الاختصارات | 01-12

الاختصار ليس معنى كاملًا

يُستخدم الاختصار بعد تعريفه، ويجب فهم السياق لأن بعض الاختصارات قد تحمل معاني مختلفة خارج الأمن والهندسة.

EPC — **Engineering, Procurement and Construction**
الهندسة والتوريد والإنشاء

AEC — **Architecture, Engineering and Construction**
العمارة والهندسة والإنشاءات

CDE — **Common Data Environment**
بيئة البيانات المشتركة

BIM — **Building Information Modelling**
نمذجة معلومات البناء

CPS — **Cyber-Physical System**
نظام سيبراني فيزيائي

DT — **Digital Twin**
التوأم الرقمي

OT — **Operational Technology**
تقنية التشغيل

IT — **Information Technology**
تقنية المعلومات

IACS — **Industrial Automation and Control Systems**
أنظمة الأتمتة والتحكم الصناعي

ICS — **Industrial Control System**
نظام تحكم صناعي

PLC — **Programmable Logic Controller**
متحكم منطقي قابل للبرمجة

SCADA — **Supervisory Control and Data Acquisition**
التحكم الإشرافي وجمع البيانات

دليل الاختصارات | 13-24

الاختصار ليس معنى كاملًا

يُستخدم الاختصار بعد تعريفه، ويجب فهم السياق لأن بعض الاختصارات قد تحمل معاني مختلفة خارج الأمن والهندسة.

HMI — **Human-Machine Interface**
واجهة الإنسان والآلة

BMS — **Building Management System**
نظام إدارة المبنى

IoT — **Internet of Things**
إنترنت الأشياء

DCS — **Distributed Control System**
نظام تحكم موزع

IAM — **Identity and Access Management**
إدارة الهوية والوصول

IIoT — **Industrial Internet of Things**
إنترنت الأشياء الصناعي

SSO — **Single Sign-On**
الدخول الموحد

MFA — **Multi-Factor Authentication**
المصادقة متعددة العوامل

ABAC — **Attribute-Based Access Control**
التحكم بالوصول وفق السمات

RBAC — **Role-Based Access Control**
التحكم بالوصول وفق الدور

VPN — **Virtual Private Network**
شبكة خاصة افتراضية

PAM — **Privileged Access Management**
إدارة الوصول المميز

دليل الاختصارات | 25-36

الاختصار ليس معنى كاملًا

يُستخدم الاختصار بعد تعريفه، ويجب فهم السياق لأن بعض الاختصارات قد تحمل معاني مختلفة خارج الأمن والهندسة.

EDR
Endpoint Detection and Response
كشف واستجابة الطرفيات

ZTNA
Zero Trust Network Access
وصول شبكي قائم على انعدام الثقة

SIEM
Security Information and Event Management
إدارة معلومات وأحداث الأمن

XDR
Extended Detection and Response
كشف واستجابة ممتدة

IDS
Intrusion Detection System
نظام كشف التسلل

SOC
Security Operations Center
مركز عمليات الأمن

WAF — **Web Application Firewall**
جدار حماية تطبيقات الويب

IPS — **Intrusion Prevention System**
نظام منع التسلل

CVE — **Common Vulnerabilities and Exposures**
معرفات الثغرات الشائعة

DLP — **Data Loss Prevention**
منع فقد/تسرب البيانات

KEV — **Known Exploited Vulnerabilities**
ثغرات معروفة بالاستغلال الفعلي

CVSS — **Common Vulnerability Scoring System**
نظام تسجيل شدة الثغرات

دليل الاختصارات | 37-48

الاختصار ليس معنى كاملًا

يُستخدم الاختصار بعد تعريفه، ويجب فهم السياق لأن بعض الاختصارات قد تحمل معاني مختلفة خارج الأمن والهندسة.

ISMS — **Information Security Management System**
نظام إدارة أمن المعلومات

CSF — **Cybersecurity Framework**
إطار الأمن السيبراني

IR — **Incident Response**
الاستجابة للحوادث

C-SCRM — **Cybersecurity Supply Chain Risk Management**
إدارة مخاطر سلسلة الإمداد السيبرانية

DR — **Disaster Recovery**
التعافي من الكوارث

BCP — **Business Continuity Plan**
خطة استمرارية الأعمال

RPO — **Recovery Point Objective**
نقطة الاستعادة المستهدفة

RTO — **Recovery Time Objective**
زمن الاستعادة المستهدف

KPI — **Key Performance Indicator**
مؤشر أداء رئيسي

SLA — **Service Level Agreement**
اتفاقية مستوى الخدمة

TTP — **Tactics, Techniques and Procedures**
تكتيكات وتقنيات وإجراءات

KRI — **Key Risk Indicator**
مؤشر مخاطر رئيسي

دليل الاختصارات | 49-60

الاختصار ليس معنى كاملًا

يُستخدم الاختصار بعد تعريفه، ويجب فهم السياق لأن بعض الاختصارات قد تحمل معاني مختلفة خارج الأمن والهندسة.

IOA — **Indicator of Attack**
مؤشر هجوم

IOC — **Indicator of Compromise**
مؤشر اختراق

SaaS — **Software as a Service**
البرمجيات كخدمة

API — **Application Programming Interface**
واجهة برمجة تطبيقات

PaaS — **Platform as a Service**
المنصة كخدمة

IaaS — **Infrastructure as a Service**
البنية التحتية كخدمة

PKI — **Public Key Infrastructure**
بنية المفتاح العام

TLS — **Transport Layer Security**
أمن طبقة النقل

MDM **Mobile Device Management**
إدارة الأجهزة المحمولة

BYOD **Bring Your Own Device**
استخدام الجهاز الشخصي في العمل

SL-T **Target Security Level**
مستوى الأمن المستهدف

SBOM **Software Bill of Materials**
قائمة مكونات البرمجيات

دليل الاختصارات | 61-61

الاختصار ليس معنى كاملًا

يُستخدم الاختصار بعد تعريفه، ويجب فهم السياق لأن بعض الاختصارات قد تحمل معاني مختلفة خارج الأمن والهندسة.

SUC **System Under Consideration**
النظام محل الدراسة وفق IEC 62443-3-2

الملحق C | مقارنة الأطر

لا يوجد إطار واحد لكل سؤال

مراجع الموضوع: [R01] [R07] [R08] [R09]

الإطار/المعيار	الغرض	المحور	حدود الاستخدام
NIST CSF 2.0	إدارة مخاطر الأمن السيبراني لجميع المؤسسات	• Govern • Identify • Protect • Detect • Respond Recover	ليس معيار شهادة ولا يفرض ضوابط بعينها
ISO/IEC 27001:2022	نظام إدارة أمن المعلومات ISMS	متطلبات نظام إدارة ومخاطر وتحسين مستمر	قابل للتصديق ضمن نطاق محدد
ISO/IEC 27002:2022	إرشادات ضوابط أمن المعلومات	ممارسات وضوابط إرشادية	ليس معيار شهادة مستقلًا
ISO 19650-5:2020	الإدارة الواعية أمنيًا للمعلومات في البيئة المبنية/BIM	الحساسية والثقافة وإدارة المعلومات عبر دورة الأصل	متخصص للبيئة المبنية والمعلومات الحساسة

الملحق C | مقارنة الأطر

لا يوجد إطار واحد لكل سؤال

مراجع الموضوع: [R10] [R11] [R12] [R13]

الإطار/المعيار	الغرض	المحور	حدود الاستخدام
IEC 62443-3-2	تقييم مخاطر تصميم IACS	SUC • Zones • Conduits • SL-T	مخصص للأتمتة والتحكم الصناعي
IEC 62443-3-3	متطلبات أمن النظام في IACS	متطلبات تقنية ومستويات أمان	مخصص للأنظمة الصناعية
IEC 62443-2-1:2024	برنامج أمن مالك IACS	سياسات وإجراءات تشغيلية لمالك الأصل	يراعي الأنظمة القديمة طويلة العمر
CISA CPGs	خط أساس مختصر عالي الأثر	ممارسات طوعية لـIT وOT	أداة بداية/أولوية وليست بديلًا عن تقييم الخطر

قاعدة اختيار

ابدأ بالسؤال ونطاق المخاطر، ثم اختر المرجع المناسب. يمكن الجمع بين CSF كإطار نتائج، وISO كإدارة، و62443 IEC لـOT، و19650-5 ISO للمعلومات في البيئة المبنية.

أداة YK7 إجرائية

النموذج السباعي
للقراءة المؤسسية السيبرانية

مراجع الموضوع: [R01] [R22]

أداة تنظيم تحليلية من بناء YK7 وليست معيارًا دوليًا. تستخدم سبع عدسات لربط الأدلة التقنية بسياق المؤسسة قبل التوصية.

1 | السياق

نموذج العمل، الأطراف، الالتزامات، والوظائف الحرجة.

2 | الأصول والمعلومات

ما الذي له قيمة؟ أين يوجد؟ من يملكه؟

3 | الثقة والوصول

الهويات والصلاحيات والحدود ومسارات الاتصال.

4 | الاستمرارية

التوافر والنسخ والتعافي والبدائل.

نموذج YK7 | تتمة

ثلاث عدسات تكمل الصورة

6 | IT/OT

أين تلتقي المعلومات بالعملية المادية؟ وما أثر السلامة والتوافر؟

5 | الطرف الثالث

الموردون، المقاولون، البرمجيات، الدعم والوصول البعيد.

النتيجة

تتحول الفجوات إلى أسئلة تحقق، ثم أولويات، ثم خارطة طريق قابلة للقياس.

7 | جودة القرار

هل الأدلة كافية؟ هل الأولويات مرتبطة بالمخاطر؟ من يملك القبول والتمويل والتنفيذ؟

لا يحل النموذج محل NIST أو ISO أو IEC؛ بل ينظم قراءة المؤسسة ويحدد أي مرجع متخصص نحتاجه.

الملحق E | قائمة فحص

خط أساس مؤسسي

قاعدة الدليل

أمام كل إجابة إيجابية اسأل: ما الدليل؟ من يملك العملية؟ متى روجعت؟ وهل النطاق يشمل الأنظمة والمواقع والموردين المعنيين؟

هذه القائمة أداة لفتح الحوار وجمع الأدلة، وليست Audit مكتملًا ولا تعطي درجة نضج تلقائية.

هل تصنف البيانات؟	هل توجد قائمة أصول؟
هل MFA للحسابات الحساسة؟	هل الحسابات الفردية إلزامية؟
هل يوجد سجل للحوادث؟	هل النسخ تُختبر بالاستعادة؟
هل تُراجع الصلاحيات دوريًا؟	هل هناك مالك واضح لمخاطر الأمن؟
هل الموردون داخل نطاق المخاطر؟	هل توجد عملية لإغلاق حسابات المغادرين؟

الملحق E | قائمة فحص

المورد والوصول البعيد

هذه القائمة أداة لفتح الحوار وجمع الأدلة، وليست Audit مكتملًا ولا تعطي درجة نضج تلقائية.

هل الوصول محدود بزمن؟	هل للمورد حساب مستقل؟
هل المسار عبر قناة معتمدة؟	هل MFA مفعل؟
هل يستطيع الوصول إلى أنظمة خارج نطاق عمله؟	هل يُسجل الدخول المهم؟
كيف يُلغى الوصول؟	من يوافق على الجلسة؟
هل تعاد/تحذف البيانات عند الإنهاء؟	هل العقد يتضمن إخطارًا بالحوادث؟

الملحق E | قائمة فحص

OT/ICS

هذه القائمة أداة لفتح الحوار وجمع الأدلة، وليست Audit مكتملًا ولا تعطي درجة نضج تلقائية.

هل توجد خريطة Zones/ Conduits؟	هل جرى جرد أصول OT؟
هل الوصول البعيد للمورد مضبوط؟	هل IT وOT مفصولان وفق الحاجة؟
هل التحديثات تُختبر وتنسق تشغيليًا؟	هل توجد نسخ إعدادات/برامج قابلة للاستعادة؟
هل تسجيل الأحداث ممكن دون التأثير في التشغيل؟	هل الحسابات الافتراضية ألغيت؟
هل مالك الأصل مشارك في القرار؟	هل خطة الاستجابة تراعي السلامة؟

الملحق E | قائمة فحص

BIM/CDE

هذه القائمة أداة لفتح الحوار وجمع الأدلة، وليست Audit مكتملًا ولا تعطي درجة نضج تلقائية.

هل النسخ والإصدارات مضبوطة؟	هل الأدوار والصلاحيات معرفة؟
هل المشاركة الخارجية محدودة؟	هل مسار الاعتماد موثق؟
هل الإزالة/الاحتفاظ محددان؟	هل المعلومات الحساسة مصنفة؟
هل سجلات التغيير متاحة؟	هل حسابات المشروع تُغلق عند الانتهاء؟
هل تطبق مبادئ Security-Minded Information Management؟	هل التسليم النهائي يشمل مسؤوليات أمنية؟

الملحق E | قائمة فحص

Ransomware Readiness

هذه القائمة أداة لفتح الحوار وجمع الأدلة، وليست Audit مكتملًا ولا تعطي درجة نضج تلقائية.

هل MFA على الوصول البعيد؟	هل الأصول الحرجة معروفة؟
هل النسخ محمية من نفس الاعتمادات؟	هل الثغرات المستغلة فعليًا ذات أولوية؟
هل يوجد Playbook؟	هل الاستعادة مختبرة؟
هل يمكن عزل جزء من الشبكة؟	هل جهات الاتصال القانونية والإدارية معروفة؟
هل نُفّذ تمرين مكتبي خلال 12 شهرًا؟	هل توجد سجلات كافية للتحقيق؟

الملحق E | قائمة فحص

إغلاق المشروع

هذه القائمة أداة لفتح الحوار وجمع الأدلة، وليست Audit مكتملًا ولا تعطي درجة نضج تلقائية.

هل أُغلقت VPN وقنوات الموردين؟	هل أُلغيت حسابات الفرق المنتهية؟
هل نُقلت ملكية الحسابات الإدارية؟	هل سُحبت الأجهزة والأصول؟
هل أُرشفت النسخة المعتمدة؟	هل سُلّمت المفاتيح والشهادات؟
هل سُجّل ما بقي من استثناءات؟	هل حُذفت النسخ غير اللازمة وفق السياسة؟
هل يوجد مسؤول يوقع على Cyber Closeout؟	هل جرى فحص الوصول بعد الإغلاق؟

سيناريو تطبيقي 1

Ransomware قبل موعد تسليم حرج

مراجع الموضوع: [R03] [R06] [R14]

يبلغ فريق المشروع أن منصة الملفات لا تفتح، وبعض الأجهزة تعرض رسالة فدية. في الوقت نفسه يوجد مورد خارجي كان لديه وصول بعيد في الليلة السابقة.

السؤال الإداري

ما الوظيفة الحرجة؟ هل توجد بدائل عمل؟ من يملك قرار إيقاف/استمرار أجزاء من المشروع؟

أول 30 دقيقة

سلامة الأشخاص والعمليات، قنوات التصعيد، عزل مدروس، منع التغييرات العشوائية، حفظ الأدلة.

التعافي

استعادة موثوقة من نقطة نظيفة مع تغيير الاعتمادات والتحقق من سلامة البيئة.

السؤال التقني

ما النطاق؟ ما نقطة الدخول؟ هل الهوية أو النسخ أو المورد تأثر؟

سيناريو تطبيقي 2

مورد BMS يحتاج وصولًا عاجلًا

مراجع الموضوع: [R15] [R02] [R04]

نظام إدارة مبنى يحتاج دعمًا عن بعد. المورد يطلب أداة Remote Desktop مباشرة، ويقول إن العمل يجب أن يتم فورًا لتجنب تأخير التشغيل.

النطاق

الوصول إلى النظام المطلوب فقط، لا إلى شبكة أوسع.

الهوية

حساب شخصي معروف، MFA، وموافقة محددة.

الأثر

تسجيل النشاط المهم وتنسيق أي تغيير مع المالك/التشغيل.

الزمن

فتح الجلسة للحاجة واغلاقها بعدها، لا وصول دائم.

العجلة التشغيلية لا تُلغى؛ لكنها تُدار داخل مسار وصول معروف بدل أن تتحول إلى استثناء دائم.

المراجع والتوثيق

المصادر والمعايير والدراسات

أُثبتت المراجع بصيغتها التعريفية المختصرة لتسهيل الرجوع. عند استخدام معيار مدفوع، لا يعيد هذا المرجع نشر نصه المحمي وإنما يشرح مفهومه في حدود المصادر الرسمية المتاحة.

[R01] NIST — Pascoe, C., Quinn, S., & Scarfone, K. (2024). The NIST Cybersecurity Framework (CSF) 2.0. NIST CSWP 29. DOI: 10.6028/NIST.CSWP.29.

[R02] NIST — Stouffer, K. et al. (2023). Guide to Operational Technology (OT) Security. NIST SP 800-82 Rev. 3. DOI: 10.6028/NIST.SP.800-82r3.

[R03] NIST — Nelson, A., Rekhi, S., Scarfone, K., & Souppaya, M. (2025). Incident Response Recommendations and Considerations for Cybersecurity Risk Management. NIST SP 800-61 Rev. 3. DOI: 10.6028/NIST.SP.800-61r3.

[R04] NIST — Boyens, J. et al. (2024 update). Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations. NIST SP 800-161 Rev.1 Update 1. DOI: 10.6028/NIST.SP.800-161r1-upd1.

[R05] NIST — Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). Zero Trust Architecture. NIST SP 800-207. DOI: 10.6028/NIST.SP.800-207.

[R06] NIST — Fisher, W., Souppaya, M., Barker, W., & Kent, K. (2026). Ransomware Risk Management: A Cybersecurity Framework 2.0 Community Profile. NIST IR 8374 Rev.1. DOI: 10.6028/NIST.IR.8374r1.

[R07] ISO — ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements.

[R08] ISO — ISO/IEC 27002:2022. Information security, cybersecurity and privacy protection — Information security controls.

[R09] ISO — ISO 19650-5:2020. Information management using BIM — Part 5: Security-minded approach to information management. Confirmed current in 2025.

[R10] IEC — IEC 62443-3-2:2020. Security for industrial automation and control systems — Security risk assessment for system design.

[R11] IEC — IEC 62443-3-3:2013. Industrial communication networks — Network and system security — System security requirements and security levels.

[R12] IEC — IEC 62443-2-1:2024. Security program requirements for IACS asset owners.

[R13] CISA — CISA. Cross-Sector Cybersecurity Performance Goals (CPGs). Baseline, voluntary high-impact cybersecurity practices for IT and OT.

[R14] CISA — CISA. #StopRansomware Guide (2023). Prevention best practices and response checklist.

[R15] CISA — CISA. Guide to Securing Remote Access Software (2023). Detection and security recommendations for remote access tools.

[R16] CISA — CISA. Known Exploited Vulnerabilities (KEV) Catalog. Authoritative catalog of vulnerabilities known to be exploited in the wild.

[R17] Academic — Pärn, E. A., Ghadiminia, N., García de Soto, B., & Oti-Sarpong, K. (2024). A perfect storm: Digital twins, cybersecurity, and general contracting firms. Developments in the Built Environment, 18, 100466. DOI: 10.1016/j.dibe.2024.100466.

[R18] Academic — Sonkor, M. S., & García de Soto, B. (2021). Operational Technology on Construction Sites: A Review from the Cybersecurity Perspective. Journal of Construction Engineering and Management, 147(12). DOI: 10.1061/(ASCE)CO.1943-7862.0002193.

[R19] Academic - Yao, D., & García de Soto, B. (2024). Assessing cyber risks in construction projects: A machine learning-centric approach. Developments in the Built Environment, 20, 100570. DOI: 10.1016/j.dibe.2024.100570.

[R20] Industry — Verizon (2026). Data Breach Investigations Report (DBIR) 2026. Global breach trends; use as contextual evidence, not construction-specific probability.

[R21] Industry — IBM & Ponemon Institute (2026). Cost of a Data Breach Report 2026. Global breach-cost and AI-related threat indicators; not construction-specific estimates.

[R22] منصة الرصد الاستراتيجي | YK7. (2026).
الأمن السيبراني في بيئة المقاولات والهندسة: ملف الرصد المؤسسي الأولي (20 صفحة).
وثيقة تأسيسية أعيد بناؤها وتوسيعها في هذا الكتاب.

عن الكتاب

من الرصد إلى المعرفة القابلة للاستخدام

هذا الكتاب جزء من ملفات الرصد المؤسسي لمنصة الرصد الاستراتيجي | YK7، ويهدف إلى وصل المعرفة التقنية بالسياق المؤسسي وجودة القرار.

إعداد وتحليل

منصة الرصد الاستراتيجي | YK7

إشراف: د. ياسر قطب

Monitoring & Observation • Analysis • Foresight • Decision Support

dryasserkotb.com

تم التحقق من الإصدارات المرجعية الرئيسة حتى سبتمبر 2026. ينبغي مراجعة حالة المعايير والإرشادات عند أي تحديث لاحق قبل استخدامها في متطلبات تعاقدية أو تدقيق رسمي.

YK7

الخلاصة

الأمن السيبراني لا يبدأ من الأداة...

بل من فهم المؤسسة

حين نفهم الأصول والثقة ومسارات الوصول والطرف الثالث والأثر التشغيلي، يصبح الأمن جزءًا من جودة القرار، لا وظيفة تقنية معزولة.

الرصد • التحليل • الاستشراف • دعم القرار

dryasserkotb.com

YK7

عن هذا المرجع

يقدم هذا المرجع قراءة علمية تطبيقية للأمن السيبراني في بيئة المقاولات والهندسة، مع ربط حماية المعلومات بمرونة المشروع والأنظمة التشغيلية.

يناقش الأصول الرقمية والهويات والوصول والموردين ونمذجة معلومات البناء والأنظمة التشغيلية، ويصل بين إدارة المخاطر وجودة القرار المؤسسي.

الموضوعات الرئيسة

- البيئة الهندسية الرقمية وإدارة الأصول
- تكامل أمن IT/OT وسلسلة الإمداد
- BIM/CDE وحوكمة البيانات
- الاستجابة للحوادث والمرونة السيبرانية
- الجاهزية المؤسسية ودعم القرار



من المعرفة التقنية إلى قرار مؤسسي قابل للتنفيذ

إعداد وتحليل: منصة الرصد الاستراتيجي | YK7

فريق إعداد الكتاب: المهندس سهيل ياسر قطب

إشراف علمي وتحريري: د. ياسر قطب

September 2026 • dryasserkotb.com